1 INTRODUCTION

Enterprise Risk Management (ERM) is the culture, capabilities and practices integrated with strategy-setting and its performance that organizations rely on to manage risk in creating, preserving, and realizing value.

This Operational Manual sets out SNGPL's approach towards risk and its management together with the means for identifying, analyzing and managing risk in order to minimize its likelihood and impact. Risk Management Department's Policy and Procedures should be read in conjunction with the SNGPL's Policy and Procedures.

All activities undertaken by SNGPL carry certain risks. The exposure to these risks is managed through the practice of risk management within each department and managing risk is the responsibility of everyone in SNGPL.

This Operational Manual outlines SNGPL's Risk Management policy and procedures which set out the guidelines for identification, assessment, treatment and monitoring of risks considered significant to the organization.

- ## Objective

1. The objective of this Operational Manual is to promote the Risk Management culture and awareness of risks in every department of SNGPL by minimizing potential Strategic, Financial, Reputational, Operational and Compliance risks arising during their course of operations.

2. This Operational Manual aims to further strengthen the existing Risk Management activities and practices and bring SNGPL under the broader ambit of 'entity-wide risk management' philosophy.

3. Risk Management Department shall play a key role in managing and overseeing risks starting from promoting 'Risk Literacy' and inculcating a strong 'risk culture' across all business activities/function at all levels in SNGPL.

- ## Authority

All employees of SNGPL are required to follow the policies and procedures contained in this Operational Manual while undertaking the risk management process.

- ## Custody

This Manual shall remain in custody of the following:

- Managing Director (MD).
- Deputy Managing Director (Services).
- General Manager (Risk Management).
- Company Secretary.

This manual shall remain the property of SNGPL therefore, copies of this must not be provided to any external party except with the prior approval of the above- mentioned custodians. However, access to this manual shall not be restricted from such external parties who are entitled to it in accordance with the provision of any law for the time being in force.

- ## Revision

The overall responsibility for maintaining and updating this Manual resides with the GM - Risk Management along with the consent of the MD. Changes in the statute, SNGPL's legal form & other conditions and practices may require periodic modifications of these policies and procedures.

After each revision, GM Risk Management shall send the updated Operational Manual to RMC in the next meeting.

Feedback comments, corrections and improvement on this manual may be submitted to GM - Risk Management for consideration as per following template:

- ## Definitions of Key Terms

The following terms with the specified meanings are used throughout this Manual:

The manual provides definitions of key terms related to risk management.

The terms are defined as follows:

1. **Business Context** is defined as the trends, events, relationships, and other factors that may influence clarify or change an entity's current and future strategy and business objectives.
2. **Business Objectives** are those measurable steps the organization takes to achieve its strategy.
3. **Consequence** refers to the outcome or impact of an event.
4. **Control** is described as an existing process, policy, device, or practice that acts to minimize risks or enhance opportunities.
5. **Core Values** are the entity's beliefs and ideas about what is good or bad, acceptable or unacceptable, which influence the behavior of the organization.
6. **Culture** is the attitudes, behaviors, and understanding of risk, both positive and negative that influence the decisions of management and personnel and reflect the mission, vision, and core values of the organization.
7. **Data** is raw facts that can be collected together to be analyzed, used, or referenced.
8. **Enterprise Risk Management** is the culture, capabilities, and practices, integrated with strategy-setting and its performance that organizations rely on to manage risk in creating, preserving, and realizing value.
9. **Entity / Company / Organisation** is Sui Northern Gas Pipelines Limited (SNGPL).
10. **Event** is an occurrence or set of occurrences.
11. **External Environment** constitutes anything outside of the entity that influences the ability to achieve strategic and business objectives.
12. **Frequency** is a measure of the number of occurrences per unit of time.
13. **Impact** is the result or effect of risk, noting there may be a range of possible impacts associated with risk.
14. **Information** is processed, organized, and structured data concerning a particular fact or circumstance.
15. **Internal Environment** constitutes anything inside of the entity that influences the ability to achieve strategic and business objectives.
16. **Likelihood** is the possibility that a given event will occur.
17. **Loss** is any negative consequence or adverse effect, financial or otherwise.
18. **Mission** is the entity's core purpose, which establishes what it wants to accomplish and why it exists.
19. **Monitor** means to check, supervise, or record the progress of an activity or system on a regular basis to identify any change.
20. **Operating Structure** is the way the entity organizes and carries out its day-to-day operations.
21. **Opportunity** is an action or potential action that creates or alters goals or approaches for creating, preserving, and realizing value.
22. **Portfolio View** is a composite view of risk the entity faces, which positions management and the board to consider the types, severity, and interdependencies of risks and how they may affect the entity's performance relative to its strategy and business objectives.

23. **Practices** are the methods and approaches deployed within an entity relating to managing risk.
24. **Residual Risk** is the remaining level of risk after risk treatment measures has been taken.
25. **Risk** is the possibility that events will occur and affect the achievement of strategy and business objectives.
26. **Risk Analysis** is a systematic process to understand the nature of and to deduce the level of risk.
27. **Risk Appetite** refers to the types and amount of risk, on a broad level, an organization is willing to accept in pursuit of value.
28. **Risk Inventory** includes all risks that may impact an entity.
29. **Risk Management** encompasses the culture, processes, and structures that are directed towards realizing potential opportunities whilst managing adverse effects.
30. **Risk Management Process** is the systematic application of management policies, procedures, and practices to the tasks of communicating, establishing the context, identifying, analyzing, evaluating, treating, monitoring, and reviewing risk.
31. **Risk Matrix** is a tool for ranking and positioning risk.
32. **Risk Officer (RO)** is a collective reference to positions within the Risk Management Department, including DCO / DCE / Sr. Officer / Sr. Engineer / Ex. Officer / Ex. Engineer.
33. **Risk Owner** refers to the person(s) responsible for managing risks, typically the individual within each department directly responsible for the strategy, activity, or function that relates to the risk.
34. **Risk Profile** is a composite view of the risk assumed at a particular level of the entity or aspect of the business that positions management to consider the types, severity, and interdependencies of risks, and how they may affect performance relative to the strategy and business objectives.
35. **Risk Register** is the record of information about identified risks.
36. **Risk Tolerance** is an organization's or stakeholder's readiness to bear the risk after risk treatment in order to achieve its objectives.
37. **Risk Treatment** is defined as the process of selection and implementation of measures to modify risk.
38. **Severity** is a measurement of considerations such as the likelihood and impact of events or the time it takes to recover from events.
39. **Stakeholders** are parties that have a genuine or vested interest in the entity.
40. **Strategy** is the organization’s plan to achieve its mission and vision and apply its core values.
41. **Threat** is an event that has the potential to release the risk and produce the top event.
42. **Tolerance** refers to the boundaries of acceptable variation in performance related to achieving business objectives.
43. **Vision** includes the entity’s aspirations for its future state or what the organization aims to achieve over time.

• Document References

This manual has been developed considering the principles and guidelines provided by Risk Management Standards and best practices including the following:

- Committee of Sponsoring Organizations of the Treadway Commission (COSO) Enterprise Risk Management-Integrating with Strategy &Performance.
- International Organization for Standardization (ISO) 31000 Risk Management-Principles and Guidelines.
- International Organization for Standardization (ISO) 31010Risk Management- Risk Assessment Techniques.
- Institute of Internal Auditors (IIA) Guidelines for Risk Management Function.

2 VISION, MISSION& POLICY STATEMENT

2.1 Vision

"To create an embedded risk awareness culture and promote efficient and effective Risk Management across SNGPL at all levels to achieve organizational objectives."

2.2 Mission

"To provide guidelines for developing a comprehensive approach for all departments of SNGPL to anticipate, identify, prioritize, manage & monitor the portfolio of principal risk impacting SNGPL's Objectives. To introduce standardized policies& procedures, competencies, accountabilities, reporting structure for effective implementation of risk management framework."

2.3 Policy Statement

At SNGPL, risk management is recognized as a key aspect of Corporate Governance Principles and Code of Conduct which aims to improvise the governance practices across the business activities.

Risk Management at SNGPL is not limited to compliance of Corporate Governance Principles; it is regarded as an integral part of sound management practices and is seamlessly integrated into the company's organizational culture, policies, procedures and business plans.

At SNGPL, risk management is considered a collective responsibility at all levels of management and is not to be seen or practised as a separate activity.

Objectives of SNGPL's Risk Management Policy

The main objectives of the risk management policy at SNGPL are:

- To identify, reduce and prevent undesirable incidents or outcomes and to review past incidents and implement changes to prevent or reduce future undesirable incidents.
- To establish a risk management framework that identifies, assesses, mitigates, monitors and reports all potential risks faced by SNGPL while running operations to achieve its desired sustainable growth.
- To formalize its commitment to the principles of risk management and incorporate these principles in all areas of SNGPL.
- To encourage the development of a culture where risk management is seen as a positive attribute of decision making rather than a corrective measure.
- To ensure compliance with appropriate regulations, wherever applicable, through the adoption of best practices.

Objectives of Risk Management Department

The main objectives of the Risk Management Department are to assist the Risk Management Committee of the Board of Directors and the Management to:

- Identify, reduce and prevent undesirable incidents or outcomes and to review past incidents and implement changes to prevent or reduce future undesirable incidents.
- Establish a risk management framework that identifies, assesses, mitigates, monitors and reports all potential risks faced by the company while running operations to achieve the desired sustainable growth of the company.
- Formalize its commitment to the principles of risk management and incorporate these principles in all areas of the company.
- Encourage the development of a culture where risk management is seen as a positive attribute of decision making rather than a corrective measure.
- Ensure compliance with appropriate regulations, wherever applicable, through the adoption of best practices.

3 ROLE OF BOARD OF DIRECTORS AND SENIOR MANAGEMENTIN ERM

The functions and delegations of BOD and Senior Management are given below:

3.1 Board of Directors

The "Listed Companies Corporate Governance Regulations" and "Public Sector Companies (Corporate Governance) Rules" as updated from time to time provide detailed guidelines and responsibilities of the Board of Directors for Risk Management.

The BoD is obligated to comply with the above-mentioned regulations and rules and ensure compliance of the same.

3.2 Risk Management Committee

The Risk Management Committee (RMC) will have specific responsibilities that include, but are not limited to, oversight and approval of the enterprise risk management framework commensurate with the complexity of SNGPL:

The terms of reference of RMCinclude the following;

1) Apprising the Board of Directors on SNGPL's overall risk management strategy and risk management policy.
2) Reviewing information on the company's Risk Management Framework that is required to be disclosed in the Director's report to be incorporated in the annual report of the company.
3) Reviewing and recommending the Risk Management Framework for identifying, monitoring and managing significant business risks which include Strategic, Financial, Compliance, Operational and Reputation risks collectively termed as Principal risks to the Board of Directors for approval, based on information provided by the management.
4) Reviewing the evaluation of emerging risks presented by the management.
5) Providing guidance to management to establish and maintain a sound risk management culture within the Company.
6) Reviewing the effective implementation of risk management policies and strategies carried out by the management and measures taken by departments for achieving a prudent balance between risk and reward in both ongoing and new business activities.
7) Reviewing steps taken by management to ensure adequate independence of the risk management function within the company and the processes for resolution and possible escalation of differences that might arise between risk management and business functions.
8) Reviewing periodic status and implementation of the risk management activities/processes being carried out by any other committee of the BoD and providing recommendations, wherever deemed necessary.
9) Any other matter entrusted by the Board of Directors

The above-mentioned responsibilities are performed by RMC on behalf of the BOD however; the BOD shall be ultimately responsible for the final approval of the risk management policies.

Other Responsibilities

1) Recommending the appointment and removal of the GM (Risk Management) to the HR&NC committee of the Board of Directors.
2) Reviewing the performance of the designated GM (Risk Management).
3) Reviewing the nature, role, scope, responsibility & authority of the Risk Management Department.
4) Reviewing the adequacy and effectiveness of the Risk Management function within SNGPL.

3.3 Managing Director

The Managing Director (MD) is reportable to the BOD and is responsible for overall ERM culture, capabilities, and practices required to achieve SNGPL's objectives. MD along with senior management set the tone at the top along with the explicit and implicit values, behaviours, and norms that define the culture of SNGPL.

The MD's responsibilities relating to ERM include:

1. Providing leadership and direction to senior members of management, and shaping the SNGPL's core values, standards, expectations of competence, organizational structure, and accountability.

2. Evaluating alternative strategies by, choosing a strategy, based on business objectives that consider supporting assumptions relating to business context, resources, and capabilities of SNGPL.

3. Maintaining oversight of the risks faced by SNGPL (e.g., directing all management and other personnel to proactively identify, assess, prioritize, respond to and report risks that may impede the ability to achieve the organizational objectives).

4. Guiding the development and monitoring of the ERM process across SNGPL and delegating responsibilities to various levels of management.

5. Communicating expectations (e.g., integrity, competence, key policies) and information requirements (e.g., the type of planning and reporting systems SNGPL will use)

6. Establishing and implementing risk management systems for all functions and activities of SNGPL.

3.4 Other Departmental / Regional Heads

3.4.1 Risk Owners

Leadership commitment is the key to building a risk awareness culture and effective risk management process. Management Committee & Senior Management have a significant role in ensuring the success of Enterprise Risk Management in the organization.

Departmental / Regional Heads (GM) working as Company leaders are the Risk Owners of their respective functions. Their objective should be to proactively manage risk and prevent risk rather than only correcting risk situations. Senior leaders have distinct responsibilities in all areas of the risk management process.

Furthermore, they shall require updating their SOP's and departments manual in the context of SNGPLs' risk management strategy and policies in order to highlight the significance of risk management in planning & decision making.

3.4.2 Training & Development

The Departmental Heads shall actively seek to develop their own basic knowledge of risk management process and must possess a clear understanding of their roles & responsibilities in this regard.

Risk Management Department through its planned training activities shall continuously help Departmental / Regional Heads in comprehending the risk management processes to aptly manage all the emerging and existing risks within and outside Principal Risk categories which are already effecting or could have a potential impact on the achievement of their Department's Objectives.

3.4.3 Focal Person

The Departmental / Regional Heads shall nominate a senior executive (Grade VI and above) as a 'Focal Person' from their department to coordinate actively with the Risk Management Department and also to follow up on Risk Management activities within the department.

The focal person shall be responsible for the following activities

- Actively seek to engage the department's personnel to apprehend their responsibilities for Risk Management i.e. Identifying, Assessing, Treating and Monitoring,
- Compilation and updating of the risk register of their relevant department,

- Be the ‘focal’ point of all communications to and from the Risk Management Department.
- Collaborate with Risk Management Department personnel so that they may effectively manage their activities pertinent to specific departments/locations. This may include visits to different locations along with Risk Officers.

3.4.4 Reporting Related to Risk Management

In the context of risk management, Departmental/Regional heads are required to report to the Managing Director on monthly basis upon following:

- Brief of activities performed in their department related to risk management
- Updated Risk Registers of their departments
- Any other information/reports related to risk management.

3.4.5 Risk Management an Integral Concept

The Departmental / Regional Heads shall encourage the risk awareness culture within their staff and ensure that all staff understands the concept of Risk Management. They must inculcate the idea of managing risk as a part of their daily routine and not merely a box-ticking periodic activity.

The Departmental / Regional Heads shall collaborate with the Risk Management Department in the best possible manner and also make sure that all the employees within their Department comply with all the guidelines provided to them through Risk Management Department.

4 RISK MANAGEMENT DEPARTMENT'S STRUCTURE

It is the intent of the Risk Management Department's Structure not to restrict the effectiveness of the employee(s), but to provide a foundation for an effective, consistent and standardized risk management process. It is the individual responsibility of each employee to understand his roles and a responsibility set forth here and in case of any query refers the matter to the GM – Risk Management.

4.1 Organogram

Risk Management Department at SNGPL shall aspire to be a cost-effective, efficient, impactful and transparent function. It shall serve as a highly valued strategic partner and resource; providing guidelines for appropriately balancing risks and opportunities. Risk Management Department shall have a diversified structure with expertise inculcating technical knowledge from organization-wide functional divisions to ensure risk management activities across the organization.

An organogram (**Refer to Annexure A**) for Risk Management Department has been proposed keeping in view the factors like chain of command, span of control, skill set requirements in relation to SNGPL's scope of activities and departmentalization. This shall assist the Risk Management Department to inform, direct, manage and monitor the departmental activities and contribute towards the achievement of organizational objectives.

4.2 Job Descriptions

The key details regarding the General Manager (GM) – Risk Management position at SNGPL are as follows:

- **Job Grade:** VIII
- **Reports To:** DMD (Services)
- **Direct Reports:** Chief Officer / Chief Engineer - Risk Management
- **Division/Department:** Risk Management Department
- **Job Location:** Lahore – Head Office

Job Summary

The GM - Risk Management is responsible to lead the Risk Management Department and assist the RMC and management in fulfilling their respective risk oversight responsibilities. Along with the management of the department GM - Risk Management has the prime responsibility of coordination with RMC and other departmental/regional heads, providing guidelines in devising risk management policy, its development and implementation that serve as a guide for all functional units of SNGPL.

Reporting Relationships

GM - Risk Management shall report directly to the DMD (Services). GM - Risk Management shall have strong advisory relations with all Members of Management Committee i.e. CFO, SGM Audit, GM Compliance etc. for collaborating on the development and implementation of Enterprise Risk Management policies and procedures.

Duties and Responsibilities

1. Establish, maintain, and revise policies and procedures for operational activities of the Risk Management Department.
2. Provide directions to CO / CE to effectively manage the overall operations of Risk Management Department.
3. Review and approve annually a comprehensive risk management plan & financial budget for Risk Management Department.
4. Monitor the performance of the Risk Management Department and its related activities on a continuing basis and taking appropriate steps to improve its effectiveness.
5. Building and maintaining relationships with those responsible for managing risks throughout the SNGPL.
6. Developing, enhancing and embedding the risk management framework for managing risks across SNGPL.
7. Emphasize upon embedding risk awareness culture within each department and encourage a risk-based decision-making approach throughout the organization.
8. Communicating with senior management about the status of enterprise risk management, which includes discussing existing and emerging risks.
9. Monitor and review that enterprise risk management is functioning in each Department / Region and that all significant risks are being recognized and effectively managed in a timely manner.
10. Assisting the Risk Management Committee in fulfilling its risk oversight responsibilities.

11. Review overall assessment of all Principal Risks impacting the company, and report to the Risk Management Committee of the Board on at least quarterly basis with the current status of these risks and follow up actions taken by respective owners to mitigate them.
12. Provide reports as directed or requested against the Annual Risk Management Plan and Annual Budget to the Risk Management Committee.
13. Share risk training plan with the HR department, developed by the Risk Management Department, for its smooth execution & availability of resources, required across SNGPL to ensure successful achievement of ERM desired objectives.

Qualification, Experience and Skills
Qualification

In accordance with the qualification requirements of SNGPL HR policies for this grade

Experience

In accordance with the experience requirements of SNGPL HR policies for this grade

Skills

- Aptitude for strategic thinking and operational implementation
- Strong interpersonal skills and the ability to build relationships based on mutual trust and respect A high level of written and verbal communication skills
- The ability to influence and successfully persuade staff at all levels to adopt risk management practices
- Self-starter, able to display initiative and pro-active approach to problem- solving
- Able to work with diverse groups of employees

A Methodical and organized approach to planning, implementation and record keeping for all activities with a high level of attention to detail

Disclaimer

I acknowledge that I have read and fully understood the main purpose of my position and agree to the duties and responsibilities set by the management.

I understand that during my employment with SNGPL, as part of my normal duties, I may have access to confidential information and record. I agree that it is my responsibility to keep all information/record secure and confidential and I will not disclose to others or use, whether directly or indirectly, any confidential information
/record for my own benefit or for any purpose except for performance of the service to SNGPL

Here are the key details for the Chief Officer/Chief Engineer – Risk Management position:

- **Job Grade:** VII
- **Reports To:** GM Risk Management
- **Direct Report(s):** Risk Officers
- **Division / Department:** Risk Management Department
- **Job Location:** Lahore – Head Office

Job Summary

The Chief Officer (CO)/ Chief Engineer (CE) is responsible for implementing risk management policy in accordance with the overall risk management strategy.CO/CE is required to coordinate for the risk management activities within the organization and to assist the GM – Risk Management in required tasks. Further, CO/CE is also responsible for reviewing the risk management activities performed by various functions/units and apprise GM – Risk Management on the status of implementation of risk management policies and procedures.

Reporting Relationships

The CO/CE reports directly to the GM – Risk Management. Further, the CO/CE shall correspond with other Departments as the need arises or as per the directions of GM – Risk Management. CO/CE has an implied responsibility to keep the GM – Risk Management in loop for all kind of activities performed and correspondence taken place.

Duties and Responsibilities

1. Assist GM - Risk Management in leading the Risk Management Department, and also ensure effective management of the Risk Management function.
2. Prepare Annual Risk Management Plan & Annual Budget for Risk Management Department.
3. Report if the risk management model at SNGPL is aptly working, also suggest any changes required to suit the specific needs of any department and ensure smooth functionality.
4. Provide directions to the employees of Risk Management Department for efficient management of resources and achieve the desired objectives as per planned activities of risk management.
5. Continuously monitor the activities of the Risk Management Department to ensure that all policies and procedures are complied with and provide a detailed report of the same to the GM - Risk Management.
6. Actively coordinate with other Department's Chiefs and ensure that all emerging and existing risks within and outside the principal risk categories are identified, assessed and mitigated in a timely manner so that the aim to integrate ERM in decision-making process shall be achieved in all business and operational activities.
7. Assist in the progression of a standardized risk information model that enables every department of SNGPL to manage & report their risks.
8. Critically review all risk reports to ensure that all identified risks are appropriately assessed and are also addressed in line with the pre-defined risk appetite level, report to GM - Risk Management on any disagreements.
9. Build & maintain ERM related coordination, with the HR and other departments

responsible for managing risks, to develop an effective enterprise risk training program, including appropriate orientation training for new employees as well as ongoing training for existing employees in order to highlight the significance of risk management process.

10. Provide details of required enterprise risk training to HR & co-ordinate with them in ensuring successful achievement of the desired objectives from risk training programs for SNGPL employees.
11. Assist Human Resource department in identification and development of effective enterprise risk orientation for new and current employees which shall be specifically relating to risk management of the designated functional area and also ensure that the training programs successfully achieve the desired objectives.
12. Provide a comprehensive report to GM - Risk Management on at least fortnightly basis which shall include the current status of enterprise risk management program and also the details of activities performed during the reporting period.
13. Perform any tasks specifically delegated by the GM - Risk Management and also provide with any specific reports as requested by the GM - Risk Management.

Qualification, Experience and Skills
Qualification

In accordance with the qualification requirements of SNGPL HR policies for this grade

Experience

In accordance with the experience requirements of SNGPL HR policies for this grade

Skills

- Analytical skills and an eye for detail
- Ability to understand broader business issues
- Problem Solving/Analysis
- Communication proficiency
- Teamwork orientation
- Commercial awareness
- Planning and organizational skills
- Communication and presentation skills

Disclaimer
I acknowledge that I have read and fully understood the main purpose of my position and agree to the duties and responsibilities set by the management.

I understand that during my employment with SNGPL, as part of my normal duties, I may have access to confidential information and record. I agree that it is my responsibility to keep all information/record secure and confidential and I will not disclose to others or use, whether directly or indirectly, any confidential information
/record for my own benefit or for any purpose except for performance of the service to SNGPL.

Here are the key details for the Deputy Chief Officer/Deputy Chief Engineering – Risk Management position:

- **Job Grade:** VI
- **Reports To:** Chief Officer/Chief Engineering – Risk Management
- **Direct Report(s):** Team Member of Grade V & below
- **Division / Department:** Risk Management Department
- **Job Location:** Lahore – Head Office

Job Summary

The Deputy Chief Officer (DCO)/ Deputy Chief Engineering (DCE) shall co-ordinate the risk management activities within Risk Management Department in order to manage the daily operations. DCO/DCE is required to ensure that all Risk Management activities are executed in conformance with established policies and procedures and in an effective manner. DCO/DCE is also responsible to review and then provide CO/CE with all the necessary information and reports received from every functional unit across SNGPL.

Reporting Relationships

The DCO/DCE reports directly to the CO/ CE. Further, the DCO/DCE may coordinate with other Chiefs / Deputy Chiefs of the relevant departments as the need arises or as per the directions of Chief Officer. DCO/DCE has an implied responsibility to keep the CO/CE in loop for all kind of activities performed and correspondence taken place.

Duties and Responsibilities

1. Ensure that the Risk Management Plan is implemented and complied with.
2. Efficiently manage all resources, including human as well as financial, to execute all risk management activities as per the Risk Management Plan.
3. Engage with focal persons of relevant department and guide them in establishing a sound risk management reporting function within their department.
4. Help the focal person in developing an understanding and significance of Risk Register and continuously review Risk Register received from every department to confirm its usefulness.
5. Conduct workshops and provide guidelines to departments on how to identify, assess, treat and report risks by using risk management techniques.
6. Actively engage with the Focal persons and Risk Owners in order to ensure that all emerging and existing risks within and outside the Principal Risk categories are identified, assessed and mitigated in a timely manner
7. Review the potential risks identified by departments and assess the soundness of those risk and identify any other risks that may emerge or already exist within and outside the principal risk categories and make sure that identified risks are reported in risk register.
8. Assist in development of most appropriate risk appetite levels to the identified existing and potential risks as per the departmental objectives.

9. Dynamically approach all identified risks and help the relevant department in responding to the identified and assessed risk as per the defined risk appetite levels.
10. Coordinate with the risk management team & assign tasks to them (subordinate staff) for achieving the planned targets of the Risk Management Department.
11. Compile records of all risk management activities and submit a report of the same to CO/ CE on at least weekly basis.
12. Provide assistance & detailed guidance to functional units about the implementation of a standardized risk information model for reporting across SNGPL.
13. Critically review all risk reports to ensure that all identified risks are appropriately assessed and are also addressed in line with the pre-defined risk appetite level, provide professional input where needed to help departments in proper assessments of all risks.
14. Provide a comprehensive report to CO/CE on at least weekly basis which shall include the current status of enterprise risk management program and also the details of activities performed during the reporting period.
15. Perform any tasks specifically delegated by the CO/CE and also provide with any specific reports as requested by the CO/CE.

Qualification and Experience

Qualification

In accordance with the qualification requirements of SNGPL HR policies for this grade

Experience

In accordance with the experience requirements of SNGPL HR policies for this grade

Skills

- Analytical skills and an eye for detail
- Ability to understand broader business issues
- Problem Solving/Analysis
- Communication proficiency
- Teamwork orientation.
- Commercial awareness
- Planning and organizational skills
- Communication and presentation skills

Disclaimer

I acknowledge that I have read and fully understood the main purpose of my position and agree to the duties and responsibilities set by the management.

I understand that during my employment with SNGPL, as part of my normal duties, I may have access to confidential information and record. I agree that it is my responsibility to keep all information/record secure and confidential and I will not disclose to others or use, whether directly or indirectly, any confidential information

/record for my own benefit or for any purpose except for performance of the service to SNGPL.

Here are the key details for the Senior / Executive Officer / Engineer – Risk Management position:

- **Job Grade:** IV / V
- **Reports To:** CO / CE– Risk Management
- **Direct Report(s):** Subordinates
- **Division / Department:** Risk Management Department
- **Job Location:** Lahore – Head Office

Job Summary

Sr. / Ex. Officer / Engineer are responsible to assist the CO / CE in establishing specialist risk policies to support investigation of incidents and near misses. Sr. Ex. Officer / Engineer are also responsible to prepare, review and provide CO / CE with all the necessary information and reports relating to risk management of relevant Department. Sr. Ex. Officer / Engineer is also required to keep his management up to date with developments in specialist areas and highlight any weakness in the activities being reviewed for risk management at each unit level.

Reporting Relationships

The Sr. Ex. Officer / Engineer reports directly to the CO / CE. The Sr. Ex. Officer / Engineer shall coordinate with focal persons of the relevant departments as the need arises or as per the directions of CO / CE. It is the implied responsibility of Sr. Ex. Officer / Engineer to keep the CO / CE in loop for all kind of activities performed and correspondence taken place.

Duties and Responsibilities

1. Ensure that the Risk Management Plan is implemented and complied with.

2. Efficiently manage all resources – including human as well as financial, to execute all risk management activities as per the Risk Management Plan.

3. Engage with focal persons of relevant department and guide them in establishing a sound risk management reporting function within their department.

4. Help the focal person in developing an understanding & significance of Risk Register and continuously review Risk Register received from every department to confirm its usefulness.

5. Conduct workshops & provide guidelines to departments on how to identify, assess, treat & report risks by using risk management techniques.

6. Actively engage with the Focal persons and Risk Owners in order to ensure that all emerging and existing risks within and outside the Principal Risk categories are identified, assessed and mitigated in a timely manner

7. Review the potential risks identified by departments and assess the soundness of those risk and identify any other risks that may emerge or already exist within and outside the principal risk categories and make sure that identified risks are reported in risk register.

8. Assist in development of most appropriate risk appetite levels to the identified existing and potential risks as per the departmental objectives.

9. Dynamically approach all identified risks and help the relevant department in responding to the identified and assessed risk as per the defined risk appetite levels.

10. Coordinate with the risk management team & assign tasks to them (subordinate staff) for achieving the planned targets of the Risk Management Department.

11. Compile records of all risk management activities and submit a report of the same to CO / CE on at least weekly basis.

12. Provide assistance & detailed guidance to functional units about the implementation of a standardized risk information model for reporting across SNGPL.

13. Critically review all risk reports to ensure that all identified risks are appropriately assessed and are also addressed in line with the pre-defined risk appetite level, provide professional input where needed to help departments in proper assessments of all risks.

14. Provide a comprehensive report to CO / CE on at least weekly basis which shall include the current status of enterprise risk management program and also the details of activities performed during the reporting period.

15. Perform any tasks specifically delegated by the CO / CE and also provide with any specific reports as requested by the CO / CE.

Qualification, Experience and Skills

Qualification

In accordance with the qualification requirements of SNGPL HR policies for this grade

Experience

In accordance with the experience requirements of SNGPL HR policies for this grade

Skills

- Analytical skills and an eye for detail
- Ability to understand broader business issues
- Problem Solving/Analysis.
- Communication proficiency.
- Teamwork orientation.
- Commercial awareness
- Planning and organizational skills
- Communication and presentation skills

Disclaimer

I acknowledge that I have read and fully understood the main purpose of my position and agree to the duties and responsibilities set by the management.

I understand that during my employment with SNGPL, as part of my normal duties, I may have access to confidential information and record. I agree that it is my responsibility to keep all information/record secure and confidential and I will not disclose to others or use, whether directly or indirectly, any confidential information

/record for my own benefit or for any purpose except for performance of the service to SNGPL.

4.3 Group Allocation& HR Policies

Risk Management Department at SNGPL shall be placed in Services Group. Risk Management Department has a unique structure because of the scope of activities and skill set required, therefore, human resource in Risk Management Department shall be required from other groups i.e. Engineering, Finance, Accounts, and IT. Employees rotated from other groups shall hold employment criteria as per their parent group in accordance with SNGPL's HR Policies.

All other guidelines, policies and procedures shall be complied as per SNGPL's HR Manual.

4.4 Human Capital Requirement in Risk Management Department

Sui Northern Gas Pipelines Limited shall be committed to building human capital in alignment with the strategy and business objectives, similar to this approach Risk Management Department shall aim to attract, develop & retain capable individuals for smooth functioning of Risk Management function within SNGPL.

4.4.1 Establishing and Evaluating Competence

Senior Management, with Board oversight, shall define & evaluate on a regular basis the human capital needed to carry out strategy and objectives of Risk Management Department. Understanding the required competencies on a continuous basis shall help in establishing how various business processes risks should be managed & monitored and what skills should be applied in context of changing internal & external requirement. Managing Director & Senior Management under the guidance of BOD shall continuously evaluate the aforementioned requirements to ensure availability of adequate & efficient risk management resources.

The human resources function shall help promote competence by assisting Senior Management in evaluating performance of risk officials. Management shall consider the following factors when developing competence requirements;

1 Knowledge, skills, and experience with enterprise risk management.
2 Nature and degree of judgment required in relation to the organizational business & operational activities and limitations of authority to be applied to a specific position.
3 The costs and benefits of different skill levels and experience.

4.4.2 Attracting, Developing, and Retaining Individuals

The ongoing commitment to competence shall be supported by and embedded in the risk management staff recruitment process. Management at different levels shall establish the structure and process to:

1. **Attract**
   Seek out the necessary number of candidates who fit in SNGPL's desired risk-awareness culture, desired behaviors, operating style and organizational needs and who have the competence for the proposed roles in risk management.

2. **Train**
   Enable individuals to develop and maintain enterprise risk management competencies appropriate for assigned roles and responsibilities, reinforce standards of conduct and desired levels of competence, role bases training to specific needs, and consider a mix of delivery techniques, including research, and on-the-job training.

3. **Mentor**
   Provide guidance on the individual's performance regarding standards of conduct and competence, align the individual's skills and expertise with the SNGPL's strategy and business objectives, and help the individual to adapt to an evolving risk management context.

4. **Evaluate**
   Measure the performance of individuals in relation to risk management objectives and demonstrating enterprise risk management competence against agreed-upon KPIs

5. **Retain**
   Provide incentives to motivate an individual and reinforce the desired level of performance and conduct in accordance with organizational policies

Throughout this process, any behavior not consistent with standards of conduct, policies, performance expectations, and enterprise risk management responsibilities shall be identified, assessed, and corrected in a timely manner.

In addition, Senior Management in Risk Management function shall continually identify and evaluate those roles that are essential for implementation of Risk Management strategy, policy & plan of Risk Management Department. The decision

of whether a role is essential shall be made by assessing the consequences of having that role temporarily or permanently unfilled.

4.4.3 Addressing Challenges in Introduction of Risk Management Department in SNGPL

As Risk Management Department is restructuring its foundation in SNGPL so it should be well prepared to address challenges that can come from many sources. Challenges also may occur during the regular cycles of specific tasks (e.g., recommending departments to develop risk awareness culture)

Risk Management Department can positively tackle challenges by rebalancing workloads enhancing capabilities or increasing /merging resource levels, as appropriate, and continue to communicate the importance of risk management at all levels of SNGPL.

The challenges are most commonly associated with:

- Unrealistic performance targets, particularly for short-term results.
- Conflicting business objectives & risk management objectives of different stakeholders.
- Gaps in understanding the responsibilities of departments owners towards risk &Risk Management Department staff

Senior Management and the Board must be prepared to set and adjust, as appropriate, the work pressure when assigning responsibilities, designing performance measures and evaluating performance. It shall be management's responsibility to guide those to whom they have delegated authority to make appropriate decisions in the course of doing business.

4.5 Preparing for Succession

To prepare for succession, the Board of Directors (through Human Resource and Nomination Committee of the Board) and management (through Human Resource Department) must develop contingency plans for assigning responsibilities important to risk management function. In particular, succession plans for key executives need to be defined, and succession candidates should be trained, coached, and mentored for assuming the role. In doing so, more than one candidate shall be considered where practicable.

5 RISK MANAGEMENT DEPARTMENT'S SCOPE OF WORK

Risk Management Department has been established in SNGPL to assist & provide guidance to all functional units in designing & implementing efficient processes to identify, analyze & treat risk. Moreover, Risk Management Department has a separate responsibility to monitor risk profile for existing risk & the potential consequences of emerging risk.

Staff deployed in Risk Management Department shall be placed independently from operational activities. It is a prerequisite that the Risk Management Department does not perform or have responsibility for operations. A mix of roles may weaken the Risk Management function's independence.

Risk Management Department shall have responsibility to monitor and review the performance of risk management function as a whole and to assist line management of each operating unit across SNGPL in communicating relevant risk information to an appropriate level in SNGPL. The Risk Management Department shall perform activities including but not limited to the following:

1. Risk Management team will prepare guidelines for risk management to be used by each department risk owners for the implementation of the risk management tasks which should be integrated with the SNGPL's strategy & mission.
2. Risk management team shall prepare a framework reflecting policy & procedure for risk management encompassing the entire SNGPL, and where necessary Risk Management team will recommend specific amendment/improvements in processes, functions or departmental manuals & SOPs in the context of the risk management.
3. Risk Management team shall support other departments across SNGPL to develop risk management knowledge for better management of risks.
4. Risk Management team shall establish a common risk management terminology (e.g. in respect of principal risk categories, sub- categories and risk drivers and the formations appropriate to likelihood and impact assessment).
5. Risk Management team shall assist departments in the development of risk reporting by providing them technical formats & risk registers. Risk Management team shall thereon monitor the risk reporting process, including establishing a system for early warning flags or a trigger system for breaches of the SNGPL's risk appetite or risk limits.
6. GM Risk Management will ensure ongoing communication with MD and the RMC based on an independent and qualified evaluation of risk management.
7. Risk Management function shall lay the groundwork for & monitor the implementation of reporting lines that ensure risk related information is communicated to the right organizational level at the right time.
8. In addition, the Risk Management function shall monitor that the above- mentioned processes are performed adequately and effectively.

Specific activities required for establishing ERM, are mentioned below;

- Providing support and training to staff to build risk awareness within the organization.
- Assist all the Departmental / Regional heads in evaluating Employee's risk awareness and train them where necessary in order to develop risk culture in SNGPL
- Provide guidance to all departments on how to perform risk assessment, which involves identifying, describing, analyzing and estimating risks affecting their operations.
- Monitoring of risk response processes carried out by individual departments, including contingency and business continuity programs.
- Gather & maintain risk related data from within & outside SNGPL affecting in any way core functions of organization.
- Produce reports or presentations that outline findings, explain risk positions and recommend changes to incorporate risk management.

6 ANNUAL RISK MANAGEMENT PLAN AND BUDGETING

To carry on risk management activities in a structured and effective manner, Risk Management Department needs to follow efficient planning and budgeting process. All available resources including both financial and human shall be utilized in most efficient ways so that all Risk Management activities are aligned with Risk Management Department's scope as well as SNGPL's Mission.

6.1 Annual Risk Management Plan

6.1.1 Objective

The primary objective of Annual Risk Management Plan is to facilitate the execution of Risk Management activities. The Risk Management Plan for SNGPL shall be prepared to give effect to the implementation of the Risk Management Policies and Procedures and shall set out Risk Management activities planned for the applicable financial year.

6.1.2 Approach

The development of Risk Management Plan shall take into consideration:

- The Risk Management Policy;
- The Risk Management Framework;
- Available Resources;
- Urgency and Sustainability.

6.1.3 Responsibility

GM - Risk Management has overall responsibility for the preparation and submission of Annual Risk Management Plan for the approval of Risk Management Committee.CO / CE shall assist and take directions from GM - Risk Management in development of Annual Risk Management Plan.

6.1.4 Format

An illustrative template may be used to draft the Annual Risk Management Plan which is attached for reference as **Annexure B** and may be modified as per future requirements.

6.2 Annual Budget

6.2.1 Objective

Budgeting is the process of setting financial goals, forecasting future financial resources and needs, monitoring and controlling expenditures and evaluating progress towards achieving the financial goals. The principal aim of budgeting in Risk Management Department is to set objectives for the budget period.

Budgets shall also be used to control costs and measure efficiency. If the actual expenditure for a certain period is more than the budgeted expenditure for the same period, it may conclude:

- Excessive expenditures have been incurred
- Additional activities were carried out that were not foreseen, or
- The budgeted amount was at a lower end & the actual amount is more than the budgeted estimates

Therefore, a variance may lead to a positive as well as a negative conclusion. However, a deviation from budget calls for management attention to identify the reasons behind the variance so that:

- It may exert better control
- Assess whether due care was taken in preparing budgets & making estimates
- Take strategic corrective actions for future

Since budgets are always subject to certain assumptions they need to be revised and updated as and when an assumption becomes invalid.

6.2.2 Budget Classification

Following types of budget shall be prepared in Risk Management Department:

- Capital Budget
- Revenue Budget

6.2.3 Responsibility for Preparation and Approval

GM - Risk Management has overall responsibility for control of the preparation of the Annual Budget for Risk Management Department. CO / CE shall assist and take directions from GM - Risk Management in development of Annual Budget. The annual budget shall be presented and approved as per company's policy.

7 RISK MANAGEMENT PROCESS

7.1 Risk Management Framework

Policies and procedures drafted in Risk Management Framework will provide the basis for overall risk management process within SNGPL.

The Framework focuses on policies, procedures and practices that support SNGPL in decision making and achieving business objectives while considering the all relevant risks. To that end, Risk Management Department has used operating structure of SNGPL to develop a best practice that:

- **Identify Risk** Identifies new and emerging risks so that management can deploy risk responses in a timely manner.
- **Assess severity of Risk** Assesses the severity of risk, with an understanding of how the risk may change depending on the level of the entity
- **Prioritize risk** Prioritizes risks, allowing management to optimize the allocation of resources in response to those risks.
- **Implement Risk Responses** Identifies and selects responses to risk.
- **Review and Report** Continuously monitor and review the risks and provide periodic reports at different levels within SNGPL

7.2 Process Flow for Conducting Risk Management

Risk management is a structured way of examining workplace (operational area, specific tasks during projects); with risk perspective to help identify anything that could potentially cause harm and negatively impact the outcome of an activity or process. By rating such potential risks, it will enable to weigh up whether enough precautions / controls have been initiated to prevent threat (and whether additional controls are required).

It shall be advised from Risk Management Department to every department in SNGPL to adopt risk management guidelines. This Risk Assessment can be conducted to whatever depth, and in whichever defined 'Operational Areas', appropriate. For example, process for handling stock of sensitive material like pipes, gas meters is streamlined and being monitored by Stores Department.

7.3 Risk Identification

Risk Owners are responsible for risk identification within their scope of activities; Risk Management Department shall provide guidance to them about risk identification process.

7.3.1 *Process Flow for Conducting Risk Identification*

RO shall guide risk owner on how to perform risk identification within their scope of activities along with providing guidelines about techniques through which Risk owners shall enable themselves to identify risk.

Risk owners shall make sure that comprehensive risk identification is carried out and Risk Identification form **(Refer to Annexure E)** is updated no longer than 5 days after the risk identification activity session is conducted.

The focal person shall then forward the completed Risk Identification Form to Departmental / Regional Head and the relevant RO of Risk Management Department.

This activity shall result in generation of Risk ID which will further become the part of sub processes of risk management and risk register.RO shall guide Risk Owners to incorporate Risk IDs into their respective risk register.

It is suggested to develop Risk IDs containing alphanumeric code that describes a unique alphabet/number assigned to each department, followed by a hyphen, and then a sequential number of risks. For example, IT department might be coded as “IT”, with risk identified “01”

Risk ID= IT- HO - 001

In order to provide guidance on **Annexure E** for risk identification, RO shall advise participants to describe their department objectives and the risk they shall face while achieving those objectives.

7.3.2 *Identification of Risk Categories*

In considering alternative ways to achieve strategic objectives, management identifies risks associated with a range of strategic choices and considers their implications. For this reason, management of SNGPL at each departmental level / regional level should need to identify potential events that, if they occur, will affect the entity, and determine whether they represent opportunities or whether they might adversely affect the entity's ability to successfully implement strategy and achieve objectives.

This process will provide guidance and direction to every department in SNGPL for identification and segregation of Principal Risks that SNGPL faces including following;

- Strategic
- Operational
- Reputational
- Financial
- Compliance

The distinction between Strategic, Operational, Reputation, Financial & Compliance risks is also important. Each department of SNGPL must pay attention both to occurrences that could disrupt operations and also threats to the achievement of organizational objectives.

Figure below describes classification of certain risk in broad categories in order to reflect their true nature.

Strategic Risk

- Change in Economic parameter
- Intellectual Capital
- Growth Strategy
- Strategic Alliance
- Internal & Competitor Analysis
- Economic Trends
- Reaseacrh and Development
- Pricing Pressure

Operational Risk

- Product / Service Delivery
- Property
- Management
- Product Development
- Terrorist Activities
- Vendor Management
- Safeguarding of Assets
- Industry Downturn
- Human Resource`

Financial Risk

- Liquidity Risk
- Market Risk
- Interest Risk
- Settlement Risk
- Unrealistic Cost Baseline
- Credit Risk
- Exchange Rate Risk
- Taxibility Risk

Reputaion Risk

- Delivering Customer Promise
- Pressure Groups
- Workplace Safety & Culture
- Socail Media Coverage
- Political Issues
- Public Perception

Compliance Risk

- Environmental Laws & Regulations
- Litigation
- Labor related Laws
- Contracts Management Laws
- Government Contract requirement

- Data Privacy Laws
- Occupational Healt & Safety
- Code of Excellence

Strategic Risk

Strategic Risk relates to risk at corporate level & it affects the development and implementation of Business strategy set up by SNGPL BOD and senior management. It is the risk relating to the long-term performance of organization.

Operational Risk

Operational Risk relates to risk of loss from inadequate or failed internal processes, people and systems or from external events.

- Any event that disrupts the normal flow of SNGPL's business processes
- and which generates financial loss or damage due to failed procedures, systems or policies

Financial Risk

Financial Risk is the risk that involves financial loss to SNGPL. Financial risk generally arises due to instability and losses in the financial market caused by movements in stock prices, currencies, interest rates and more. Financial risk is one of the high-priority risk type for every business.

Reputation Risk

A threat to the good name or standing of a business is considered as reputation risk. SNGPL may face reputational risk through a number of ways: directly as the result of the actions of the company itself; indirectly due to the actions of an employee or employees; or tangentially through other peripheral parties, such as joint venture, partners or suppliers. In addition to having good governance practices and transparency, SNGPL also needs to be socially responsible and environmentally conscious to avoid reputational risk as SNGPL is committed towards its CSR responsibility and determined to leave a positive impact on the environment, employees, social norms and economic development.

Compliance Risk

Compliance risk is the risk of legal and regulatory sanctions, exposure to legal penalties, financial forfeiture and material loss SNGPL may faces when it fails to act in accordance with the applicable laws and regulations, code of conduct, internal policies or prescribed best practices.

7.3.3 *Risk Drivers*

When identifying events, management of each department shall consider a variety of internal and external factors that may give rise to risks and opportunities, in the context of full scope of organization.

Internal Factors

The internal factors relate to internal environment in which SNGPL operates. Defining SNGPL's internal factors requires considering, amongst other things, SNGPL**'s objectives, structure, capabilities, processes, resources and stakeholders.**

External Factors

The external factors relate to external environment in which SNGPL operates and requires considering the impacts that external factors may have on SNGPL's operations and ability to achieve its objectives. Examples include:

- **Political:** change of government, change in government policies
- **Economic:** economic growth, commodity prices, interest rates
- **Socio-cultural:** population growth, impact of demographic change on demand for services, change in stakeholder expectations, pressure groups
- **Technological:** technological change, cost of updating technology, obsolescence of systems
- **Laws and Regulations:** legislation, regulations and standards
- **Environmental:** impacts that your organization's operations have on the built or natural environment, climate change.

To identify the relevant internal and external factors, following activities shall be performed:

- Review of Objectives and Strategies
- Review of Governance, Structure, Roles and Responsibilities
- Understanding of Policies & Procedures
- Understanding of Risk Tolerance and Appetite
- Capability of People, System and Process

> Sources of risk are all of those environments, whether internal or external that can generate threats of losses or obstacles for achieving the SNGPL's objectives. Internal and external factors can give rise to risks.

The document provides a breakdown of external environment categories and their characteristics. These categories are relevant when identifying events that may give rise to risks and opportunities.

The external environment categories and characteristics include:

- **Political:** This includes the nature and extent of government intervention and influence, covering aspects like tax policy, labor laws, environmental regulations, trade restrictions, tariffs, and political stability.
- **Economic:** Encompasses factors such as interest rates, inflation, foreign exchange rates, availability of credit, and GDP growth.
- **Social:** This category relates to customer needs and expectations, population demographics (age distribution, educational levels), and distribution of wealth.
- **Technological:** Includes R&D activity, automation, technology incentives, and the rate of technology changes or disruption.
- **Legal:** This refers to laws (employment, consumer, health and safety), regulations, and/or industry standards.
- **Environmental:** This covers natural or human-caused catastrophes, ongoing climate change, and changes in energy consumption regulations, as well as general attitudes toward the environment.

The document details internal environment categories and their characteristics, which are important for identifying events that may lead to risks and opportunities.

The internal environment categories and characteristics include:

- **Capital:** This refers to assets, including cash, equipment, property, and patents.
- **People:** Encompasses knowledge, skills, attitudes, relationships, values, and culture.
- **Process:** This category relates to activities, tasks, policies, and procedures, as well as changes in management, operational, and supporting processes.
- **Technology:** Includes new, amended, and/or adopted technology.

Risk Appetite

Risk appetite is “How much and what type of risk, entity or department is prepared to accept to achieve its strategic objectives”.

There is no standard or “right” risk appetite that applies to all departments. Risk appetite may encompass a single depiction or several depictions that align and collectively specify the acceptable types and amount of risk.

Risk Appetite can be expressed in both qualitative and quantitative terms. The best approach for SNGPL shall be the one that aligns with the analysis used to assess risk in general, whether that is qualitative or quantitative.

Articulating Risk Appetite

A variety of approaches are available to determine the risk appetite, including facilitated discussions, reviewing past and current performance targets. In determining risk appetite, SNGPL may consider stakeholders who have potential impact while determining business strategy.

In SNGPL, department may develop and articulate risk appetite using other approaches, such as risk categories. These approaches could be sometimes easier to manage and assess. However, they could also result in department’s managing risk in silos rather than taking an integrated view of enterprise risk management.

When SNGPL shall become more experienced and mature in enterprise risk management, its description of risk appetite will become more precise. Although measures for determining risk appetite would align with the strategy and related business objective targets.

Management shall create a culture that emphasizes the importance of risk appetite and holds those responsible for implementing enterprise risk management within the risk appetite parameters. But risk appetite is only part of the approach. To fully embed risk appetite into decision-making at various levels, it does need to cascade through and align with other practices.

7.3.4 *Risk Identification Techniques*

Various tools and techniques may be used to identify risks in SNGPL. Following are some techniques which RO's/Risk Owners shall use to identify risks at organizational/departmental/unit/activity level.

Risk Identification Techniques

- Brain storming
- Bow-Tie Analysis
- Interviews
- Checklists
- Structured What-If Analysis
- Facilitated Workshops
- Surveys
- Incident Analysis
- Direct Observation
- Fault Tree Analysis
- Scenario Analysis

Brainstorming

Brainstorming involves discussion sessions of a small group of stakeholders in a particular field/department to identify potential risks, causes, failure modes and criteria for decisions and/or options for treatment. The objectives of this session may include any or all of following depending upon the need and circumstances;

- To discuss various risks faced by department in activities performed at every level
- To determine the risk categories from the suggestions gathered from experts at departmental level in SNGPL.
- To map all the relations between risks and consequences.
- After mapping, all risks have to be quantified and with the use of assessment model, overall risk position will be determined.

After identifying the risk, the workgroup shall brainstorm about what is the main event that happens if control over the identified risk is lost. It is important that this step is done carefully after thorough deliberations, since the next steps are based on the choices made here. As a result of this step the risks have to be mapped into a top event. It is one of the best & most popular ways to identify both risks and key controls and is the basis for most risk workshops.

The relevant Risk Officer will conduct this session as deemed necessary on the basis ofmonthly plan after getting relevant approvals and intimating concerned department and related group of people prior to when the session is held. Risk Officer shall ensure the availability of resources and distribution of agenda and material required to conduct the session.

It is required that brainstorming sessions conducted should stimulate and encourage free-flowing conversation amongst a group of knowledgeable people without criticizing or rewarding ideas. Their goal would be to identify and then help assess risk in their units and report accordingly.

Bow Tie analysis

Bow tie analysis is a diagrammatic way of describing, linking and analyzing the pathways of a risk from causes to effects/impacts.

There are no numbers in this analysis i.e. there is no risk or control evaluation involved. This keeps the focus on understanding the relationships between the causes, event and impacts.

It is suggested that after a brainstorming session, bow tie analysis is a great way to clean up the ideas generated and consolidate the results into more appropriate risk statements. **Figure** depicted below shows the process of a Bow Tie Analysis and the successive steps are explained which have to be taken while adopting this technique.

1. The starting point for Bow Tie Analysis is risk identification.
2. The second step in creating a Bow Tie diagram is defining the top event, i.e. when the risk has occurred. The top event has to answer the question: “What happens when the risk has occurred?” This formalization step is needed to come to a meaningful identification of threats, consequences and barriers.
3. After identifying the risk and defining the top event, the threats have to be identified. Threats are identified to get a complete overview of all possible ways the control of a risk can be lost.

4. The next step is to identify the impactof that event. This step should result in an exhaustive list of possible impacts that could result from the risk under consideration.
5. The last step is to identify the barriers at the left-hand side of the Top Event, which are the preventive measures and
6. The barriers on the right-hand side of the Top Event, which are the mitigation or recovery controls**.**

Risk officers are advised that prior to use of this technique they shall ensure to provide all participants of the session, a concept of Bow Tie Analysis filled with knowledge up till then (e.g. risk, top event, threats and impacts etc.).

During the session, there has to be adequate discussion about barriers for each threat of impact and their effectiveness in the three point scale. The session has to result in a completely filled Bow Tie Analysis with all known barriers assigned to the related threats or impacts. After the session, the risk owners have to link the elements from the Bow Tie Analysis to elements from the management systems (e.g. policies, procedures, guidelines, manuals, instruction, etc.) to assess that the operation and quality of the barriers are adequate and efficient.

Interviews

During a structured interview, interviewees are asked a set of open ended questions to encourage the interviewee to present their own perspective and thus identify risks.

Structured interviews are frequently used during consultation with key stakeholders during risk management process. The purpose is to ascertain the individual's candid views and knowledge of actual past events and potential events.

In practice, Risk Officers are advised to adopt following interview agenda focusing on each department's objective as illustrated below

Interview Agenda

- Introduction of Technique
- Provide background on the Risk Identification Strategy and interview process
- Confirm the position, role, background & current responsibilities of employee with whom this session is intended to take place

Strategies and Objectives

a. Identify the key objectives within the interviewee's business unit
b. Determine how the objectives are aligned with and support the SNGPL's strategies and objectives

c. Determine the established risk tolerances
d. Discuss factors related to potential events related to the objective
e. Identify potential events creating risks to objectives, and those representing opportunities
f. Consider how the employee prioritizes these events, considering likelihood and impact
g. Identify events that have occurred in the past 12 months that impacted the entity and were not identified by management or staff of relevant department
h. Consider whether risk identification mechanisms need to be enhanced

Checklists

Checklists are pre-populated lists of risks or control failures that have been developed usually from experience, either as a result of a previous risk assessment or as a result of past failures or incidents.

Each department within SNGPL shall draft checklists, in co- ordination with Risk Management Department, containing the risks faced during their operations which shall be updated regularly. The risk checklists can only be used as a secondary form of risk and control identification as relying entirely on checklists can restrict 'risk thinking'. Proposed template from Risk Management Department is described in **Annexure F.**

Structured "What-if" Technique (SWIFT)

This is a systematic, team based exercise, where the facilitator utilizes a set of 'prompt' words or phrases to stimulate participants to identify risks.

This kind of exercise should be planned at regular intervals as SWIFT considers deviations from normal operations identified by brainstorming, with questions beginning "What if…?" or "How could…?" Discussion is facilitated by creating a question using a 'what-if' phrase like "what would happen if…"etc. The intent is to stimulate the selected Department Personnel into exploring potential scenarios, their causes, impacts and impacts.

SWIFT may be used simply to identify risks for subsequent quantitative evaluation, or alternatively to provide a qualitative evaluation of the risks and to recommend further safeguards where appropriate.

The Risk Officers shall ask the participants to raise and discuss:

- Known risks;
- Previous experience and incidents;
- Known and existing controls and safeguards;

- Regulatory requirements and constraints

The risks identified are summarized and the RO shall in coordination with Risk Owner considers the controls already in place assuming that there are any before confirming the description of the risk, its causes, consequences and expected controls. The information should then be recorded in a structured manner.

Scenario Analysis

It is closely related to SWIFT. Here a scenario is a short description of a situation of how a future event or events might turn out or look like. For each scenario, participants from a department shall reflect and analyze the potential consequences and potential causes when analyzing risk.

Fault Tree Analysis (FTA)

This method is similar to a form of creative thinking called reverse brainstorming. RO shall guide about this technique to be used for identifying and analyzing factors that can contribute to a specified undesired event (called the "top event"). Causal factors are then identified and organized in a logical manner and represented pictorially in a tree diagram. Fault trees are used for analyzing events or combinations of events that might lead to a risk or an event.

For example, if improvement in customer services is required, state the objective in reverse e.g. "How can we really annoy our consumers?" and from this statement, use brainstorming to identify causes that could annoy SNGPL consumers.

Direct Observations

This relatively simple technique is used daily in the workplace by staff who may observe risky situations and risks regularly.

A risk awareness culture and well-trained staff among all department of SNGPL will improve people's ability to observe & communicate potential risks to certain level within their department and implement controls before the risk eventuates into an incident. Risk Management Department shall ensure that risk observed by any risk raiser within SNGPL will escalate the risk to Departmental / Regional Head after a comprehensive analysis and takes follow up regarding control for identified risk.

Incident Analysis

Incidents are risks that have now occurred. Recording incidents in a register, conducting root cause analysis and periodically running some trend analysis reports to analyze incidents, can potentially enable new risks to be identified as well as assessing controls for recurring risks. In addition, a high frequency of like incidents can be a lead risk indicator to a potentially larger problem.

Every department shall record each incident happened during their course of operations and escalate their mitigation strategy within organization to raise awareness for similar incidents.

Surveys

It is similar to structured interviews but involves a larger number of people. It can be used to collect a broad set of ideas, thoughts and opinions across a range of areas covering similar nature risks and control effectiveness and be advised to conduct among different departments collectively.

Risk officers can use surveys is to assess the SNGPL's risk culture. It may also be advised to use annual staff surveys to gauge staff understanding of key risk and governance policies and procedures prevailed within SNGPL.

Facilitated workshops

Risk Identification through facilitated workshops typically brings together cross- functional individuals for the purpose of drawing on the collective knowledge to develop a list of potential events bearing risks. The advantage of this mechanism is the ability to have workshops for different levels of responsibility, i.e., the governance level would have a different view of magnitude of risk than a front line staff member.

Risk workshops also permit the inclusion of the greatest number of staff from across the organization, thereby increasing their awareness of risk and their participation in finding solutions and identifying approaches to managing the risks. Decentralized risk ownership will require risk evaluation at individual activity levels, with roll up to line of business or business unit, and then an overall evaluation for SNGPL.

Prior to the workshop Risk Officer shall perform following preliminary activities:

- Identify experienced facilitator (Whether Internal or External Resource) to lead the session, manage group dynamics, and plan how best to capture generated ideas in usable form
- Establish and agree on ground rules at the commencement of the workshop with the concerned department.
- Recognize the different participant styles and personality types, considering how to optimize their contribution in order to draw productive results of the session
- Identify which objectives, category of objectives, and categories of events to focus on and agree those objectives with department owner
- Invite an appropriate number of workshop participants in liaison with selected department.

- Set realistic expectations up front with respect to what the workshop is intended to achieve

Agenda

I. Introduction - Explain background of workshop and why each participant has been invited - Explain ground rules
II. Explain workshop process - Events are to be considered against corporate objectives per business plan.
III. Explore Objective
    - Identify the objective, its unit of measure, and the related established targets
    - Gain consensus of risk tolerance -the degree of acceptable variation around the unit of measure
    - Discuss internal and external factors that drive potential events relative to the objective
    - Determine which events represent risks to achieving the objective, and which events represent opportunities
    - Consider how multiple risks affecting this objective relate to one another
IV. Next steps and close - Distribute the workshop output to all participants within 48 hours, after review & approval from Risk Management Department with action plan for next steps

7.4 Risk Assessment

As part of the risk assessment, management considers inherent risk, target residual risk, and actual residual risk.

- Inherent risk is the risk to an entity in the absence of any direct or focused actions by management to alter its severity.
- Target residual risk is the amount of risk that an entity prefers to assume in the pursuit of its strategy and business objectives, knowing that management will implement, or has implemented, direct or focused actions to alter the severity of the risk.
- Actual residual risk is the risk remaining after management has taken action to alter its severity. Actual residual risk should be equal to or less than the target residual risk. Where actual residual risk exceeds target risk, additional actions should be identified that allow management to alter risk severity further.

Management may identify risks for which unnecessary responses have been deployed. Redundant risk responses are those that do not result in a measurable change to the severity of the risk. Removing such responses may allow management to allocate resources put toward that response elsewhere

7.4.1 *Process Flow for Conducting Risk Assessment*

RO shall guide risk owner on how to conduct risk assessment once risks are identified. Detailed guidance & process flow for risk identification has been described in section**7.3 above.**

Ideally risk assessment activity shall immediately follow up after the risk identification activity session**.** Though, given the time barriers, it is probable that the Risk Assessment activity for all identified risks might not be concluded in one session.

Risk owners shall make sure that a comprehensive risk assessment is carried out and Risk Assessment form **(Refer to Annexure G)** is updated no longer than 5 days after the risk identification & assessment activity session is conducted.

The focal person shall then forward the completed Risk Assessment Form to Departmental / Regional Head and the relevant RO of Risk Management Department.

The process flow for risk assessment requires that the risks are analyzed by determining their likelihood (of occurrence) and their impact (of occurrence) and arriving at an appropriate risk rating which shall become part of risk register. This involves:

a) Calculate risk rating
   I. Using the Risk Impact descriptor, determine the most appropriate impact of

the risk occurring.

II. Using the Risk Likelihood descriptor, determine the most appropriate likelihood of the risk occurring.
III. Using the Risk Vulnerability descriptor**,** determine the most appropriate vulnerability the risk exposes to.
IV. Using the Risk Velocity (Speed of Onset) descriptor, determine the most appropriate velocity of the identified risk.
V. Using the Risk matrix (and based on the likelihood and impact identified above) determine the risk rating i.e. Extreme, High, Moderate or Low.
VI. Record the Impact, Likelihood, scores and risk rating in the relevant columns of risk assessment template (**Refer to Annexure G**).

Vulnerability and Velocity are an advanced level concept and shall be introduced at a later suitable point of time when the Risk Management Process at SNGPL will be considered mature enough.

b) Consider and record controls in place to manage the identified risk

I. Consider **existing controls** (or actions) in place to manage the identified risk. Record these controls in the "Key Control Title" column.
II. Determine the **control effectiveness percentage** to highlight the effectiveness of controls and record these in the Control Effectiveness column.
III. Complete the Control Description, Control Owner and Comments column to provide further information on identified controls. Record these in their relevant columns.
IV. Review the overall risk ratings by confirming that significant risks are captured and prioritized appropriately to reflect the Department's objectives and its operations/activities and current environment.
V. Confirmassessmentreferringtotheriskratingsanddescriptionsatthebottom of the risk assessment template.

After conducting each Risk Assessment activity session participant's responses shall be collected on a standard Feedback Form **(Refer to Annexure J)**.

Risk assessment process

Risk assessment process shall involve certain steps. Every department in SNGPL shall follow these steps while conducting assessment of identified risk. **RO** shall provide guidelines to perform risk assessment.

7.4.2 *Develop assessment criteria*

The first activity within the risk assessment process is to develop a common set of assessment criteria to be deployed across business units, corporate functions, and projects. Risks and opportunities are typically assessed in terms of impact and likelihood.

Considering the scope of activities and vast dimension of SNGPL that there are some additional requirements for providing scales to identified risks apart from just assessing their likelihood & impact.

Therefore, illustrative scales are provided for Impact, Likelihood, Vulnerability, and Speed of onset.

Risk Evaluation Matrix

The evaluation matrix provides a framework for assessing and measuring identified Risks, which shall be reviewed at various points within the governance structure to ensure appropriate priority and visibility is assigned to it.

Whilst risks in SNGPL could occur from various diverse routes, it is essential that the standards for assessing the likelihood and impact of occurrence of each risk should be subject to the same criteria across SNGPL. This shall allow the risks to be managed consistently, at the appropriate level and given the appropriate attention and visibility.

Management of every department shall be required to determine the relative severity of various risks in order to select an appropriate risk response, allocate resources & support overall SNGPL's management in decision making and performance.

Risk evaluation and quantification comprises of scores of four types;

Impact

Impact refers to the extent to which a risk event might affect SNGPL. Impact assessment criteria may include financial, reputational, regulatory, health, safety, security, environmental, employee, customer, and operational impacts. When assigning an impact rating to a risk, assign the rating for the highest impact anticipated. For example, if any one of the criteria for a rating of 5 is met, then the impact rating assigned is 5 even though other criteria may fall lower in the scale.
RO shall advise all departments that using standardized risk terminology and categories helps in the assessment of risk at all levels of SNGPL. Through this approach, common risk across certain business units, divisions & functions can also be grouped together.

Scoring – Impact

For assessing severity of risk, RO are required to guide Risk Owners from every department that they allocate a score based on the expected severity of the impact. It could be done as illustrated below;

The excerpt from the risk management manual defines the impact rating descriptors. These descriptors help to assess the severity of a risk's potential impact on SNGPL. The impact ratings range from 1 to 5, with increasing severity.

Here's a breakdown of each impact rating:

- **1 - Insignificant:** A low effect on achieving SNGPL's objectives, local media attention quickly remedied, not reportable to regulator, and isolated staff dissatisfaction.
- **2 - Minor:** A minor effect on achieving SNGPL’s objective, local reputational damage, reportable incident to regulator with no follow up, general staff morale problems, and an increase in turnover.
- **3 - Moderate:** A significant effect on achieving SNGPL’s objectives, national short-term negative media coverage, report of breach to regulator with immediate correction to be implemented, and widespread staff morale problems with high turnover.
- **4 - Major:** A major effect on achieving SNGPL’s objectives, national long-term negative media coverage, loss of market share, report to regulator requiring major project for corrective action, some senior managers leaving, high turnover of experienced staff, and not being perceived as employer of choice.
- **5 - Catastrophic:** A disastrous effect on achieving SNGPL’s objectives, significant loss of market share, international long-term negative media coverage, significant prosecution and fines, litigation including class actions, incarceration of senior management, significant injuries or fatalities to employees or third parties (such as contractors or vendors), and multiple senior executives leaving within a short period.

Likelihood

Likelihood represents the possibility that a given event will occur. Likelihood can be expressed using qualitative terms (frequent, likely, possible, unlikely, rare), as a percent likelihood, or as a frequency.

Scoring – Likelihood

This allows an assessment of the likelihood that the risk will materialize. The Risk Owner allocates a score based on the likelihood assessment established on the basis of prior history of risk occurrence, professional judgment of assessor and state of controls, as illustrated below;

The excerpt from the risk management manual defines likelihood descriptions to assess the possibility of a given event occurring. The likelihood is scored from 1 to 5.

The likelihood scores include:

- **1 - Rare:** It is highly unlikely that the risk will materialize (less than 10% chance).
- **2 - Unlikely:** Could happen with a chance of 10% to less than 35%.
- **3 - Possible:** 35% to less than 65% chance of occurring. The event might occur at some time.
- **4 - Likely:** 65% to less than 90% chance of happening, difficult to prevent probably because outside of direct control or influence.
- **5 - Almost Certain:** Over 90% chances. Very likely. The event is expected to occur in most circumstances.

Vulnerability

Vulnerability refers to the susceptibility of SNGPL to a risk event in terms of criteria related to the SNGPL's preparedness, agility, and adaptability. Vulnerability is related to impact and likelihood. The more vulnerable the entity is to the risk, the higher the impact will be should the event occur. If risk responses including controls are not in place and operating as designed, then the likelihood of an event increases. Assessing vulnerability will allow SNGPL to gauge how well it is managing risks.

Scoring-Vulnerability

Vulnerability assessment criteria may include capabilities to anticipate events such as scenario planning (Structured way to think about future); capabilities to prevent events such as risk responses. There is no one-size-fits-all assessment scale. Each department owner is advised to define scales to meet its needs as illustrated below

The excerpt from the risk management manual defines vulnerability rating descriptors that measure SNGPL's susceptibility to a risk event. It assesses SNGPL's preparedness, agility, and adaptability. The more vulnerable SNGPL is to a risk, the higher the impact if the event occurs.

The vulnerability scale is scored from 1 to 5. Each score is defined as:

- **1 - Very Low:** Material evaluations have been made to maximize strategic flexibility, high enterprise/process level capabilities to address risks, redundant response mechanisms are in place and regularly tested for critical risks, and contingency and crisis management plans are in place.
- **2 - Low:** Strategic options are defined, medium to high enterprise/process level capabilities to address risks, responses are implemented and achieving objectives except under extreme conditions, and contingency and crisis management plans are in place with some rehearsals.
- **3 - Medium:** Stress testing and sensitivity analysis of scenarios are performed, medium enterprise/process level capabilities to address risks, responses are implemented and achieving objectives most of the time, and most contingency and crisis management plans are in place, but with limited rehearsals.
- **4 - High:** Scenario planning for key strategic risks is performed, low enterprise/process level capabilities to address risks, responses are partially implemented or not achieving control objectives, and some contingency or crisis management plans are in place.
- **5 - Very High:** No scenario planning is performed, there is a lack of enterprise/process level capabilities to address risks, responses are not implemented by departments, and no contingency or crisis management plans are in place.

Speed of Onset (or Velocity)

Speed of onset refers to the time it takes for a risk event to manifest itself, or in other words, the time that elapses between the occurrence of an event and the point at which any department of SNGPL as a whole first feels its effects. Knowing the speed of onset is useful when developing risk response plans.

Scoring – Speed of onset (or Velocity)

Following is the illustrative table for scoring velocity:

The "Illustrative Speed of Onset Scale" provides a guide for scoring the velocity, or speed of onset, of a risk. Speed of onset refers to the time it takes for a risk event to manifest or the time that elapses between the occurrence of an event and the point at which any department of SNGPL as a whole first feels its effects.

The scale ranges from 1 to 5, with each rating defined as follows:

- **1 - Very Low:** Very slow onset, occurs over a year or more.
- **2 - Low:** Onset occurs in a matter of several months.
- **3 - Medium:** Onset occurs in a matter of a few months.
- **4 - High:** Onset occurs in a matter of days to a few weeks.
- **5 - Very High:** Very rapid onset, little or no warning, instantaneous.

Knowing the speed of onset is useful when developing risk response plans.

7.4.3 *Assess risk*

Assessing risks consists of assigning values to each risk using the defined criteria. This may be accomplished in two stages where an initial screening of the risks is performed and then providing score **as described above.**
Once Risk Scoring is conducted, overall Risk Rating is required to develop. Illustrative Risk Matrix has been developed for understanding mentioned as under**;**

Overall Risk Rating

Following is an I**llustrative Risk Matrix** for overall Risk Rating

The document contains a risk matrix that combines impact and likelihood to determine an overall risk rating.

The risk matrix uses a scale of 1 to 5 for both impact and likelihood, with the following descriptors:

- **Impact:**
  - 1 = Insignificant
  - 2 = Minor
  - 3 = Moderate
  - 4 = Major
  - 5 = Catastrophic
- **Likelihood:**
  - 1 = Rare
  - 2 = Unlikely
  - 3 = Possible
  - 4 = Likely
  - 5 = Almost Certain

The overall risk rating is then determined by the intersection of the impact and likelihood scores in the matrix:

- **Extreme:** Impact 4-5 and Likelihood 4-5
- **High:** Impact 3-5 and Likelihood 3
- **Moderate:** Impact 1-3 and Likelihood 5, Impact 2-4 and Likelihood 2, or Impact 3 and Likelihood 1
- **Low:** Impact 1-2 and Likelihood 1-2

These risk scores will determine the amount and urgency of mitigation action and monitoring to manage the associated risks. Risk Escalation Protocol Table illustrated below provides guidance as to what the scores can represent in management terms.

The excerpt from the risk management manual defines a risk escalation protocol based on risk scores. This protocol outlines the required actions for different risk levels, ensuring appropriate management and monitoring.

The risk escalation protocol includes:

- **Extreme (E):** Risk score of 16-25.
  - Likely to threaten the survival or continued effective function of SNGPL.
  - Immediate action required by the Department owner.
  - Must be managed by Departmental / Regional Head and communicated to senior level with a detailed treatment & contingency plan through MD & Risk Management Department to Board.
  - Close monitoring by the board is required until closure of the incident.
- **High (H):** Risk score of 12-15.
  - Likely to cause damage, disruption, or breach of controls.
  - Senior management attention is needed, and management responsibility is specified.
  - Treatment plans to be developed and implemented by Departmental / Regional Head.
  - Close monitoring by the Risk Management Department is required until closure of the incident.
- **Medium (M):** Risk score of 5-10.
  - Unlikely to cause much damage and/or threaten the efficiency and effectiveness of SNGPL.
  - Managed by specific monitoring or response procedures by department personnel.
  - Treatment plans to be developed and implemented by operational managers, and progress reported is required to submit to department owners.
  - Close monitoring by the risk owner is required until closure of the incident. Follow-up action should be required from Risk Management Department.
- **Low (L):** Risk score of 1-4.
  - Unlikely to require specific application of resources.
  - Managed by routine control procedures.
  - Monitored and reviewed by the risk owner on a monthly basis.
  - Any change in status is promptly reported to the next level.
  - Implemented by the operational manager and reported to the risk owner.
  - Risk Management Department should give consideration to relaxation of control & suggest further guidance if required.

Risk Heat Map

The Risk Heat map is used to generate a visual representation of identified risks. Risk Heat map refines the identified & assessed risk to further prioritize and filters them for relevant risk treatment. Criteria for risk prioritize shall be developed by department and keeping in view the strategic objectives of their department & SNGPL as a whole. This approach shall filter out the less-important risks, and present a picture with focus on the more-important risks, thus improving the ability of this chart to support a Senior Management review, especially when the risk inventory consists of a large number of risks.

RO(s) are required to provide detailed guidelines to Risk Owners on how to use Risk Heat Maps in order to ascertain the Risk assessment on the basis of Vulnerability and Speed of Onset (Velocity), The Risk Heat map charts risks in the traditional manner with Impact and Likelihood on X- and Y-axis of a matrix, and then enhances the visual depiction by including Vulnerability and Speed of Onset of the risks in the chart.

Guide for use of assessment criteria in Risk Heat Map

The risk rating calculated through risk matrix shall be used to identify the positioning of risk identifier image on the Risk Heat map.
The Risk Heat map is split into squares that are characterized by the intersecting values of Impact & Likelihood. The Heat map colors are identified by ranges of I x L values, as illustrated below.

The 'I x L Product – Guide' from the risk management manual defines risk ratings based on the product of Impact (I) and Likelihood (L) scores. The risk ratings are categorized as follows:

- **Low:** I x L score range of 1-4
- **Medium:** I x L score range of 5-10
- **High:** I x L score range of 12-15
- **Extreme:** I x L score range of 16-25

These risk ratings, derived from the risk matrix, are used in the risk escalation protocol to determine the necessary actions for managing identified risks. The risk escalation protocol ensures that risks are managed and monitored at the appropriate level within SNGPL.

Vulnerability and Speed of Onset (Velocity) - Guide:

Vulnerability of risk is indicated by the shape. As Vulnerability increases, so does the number of sides of the shape used in this depiction.

Speed of Onset is depicted by the size of the images used. As the Speed of Onset (and hence the threat of the risk) increases, so does the size of the image.

This is an advanced concept and shall be introduced at a later suitable point of time when the Risk Management Process at SNGPL will be considered mature enough.

Using this Heat map technique, it is possible for a reviewer to quickly identify the risks that offer the greatest threats to the project, using the following simple rules:

- The higher the I X L value (or the deeper the color), the greater the risk severity;
- The greater the number of sides of the image used, the greater the vulnerability of the project or organization;
- The larger the image, the quicker will the risk impact the project or organization.

7.4.4 *Assess risk interactions*

Risks do not exist in isolation and it is important to recognize the significance of managing risk interactions. Even seemingly insignificant risks on their own have the potential, as they interact with other events and conditions, to cause great damage or create significant opportunity. Therefore, risk owner of every department is required to look towards an integrated or holistic view of risks by using techniques such as bow-tie diagrams. RO shall provide essential guidance for using these techniques to departments. Furthermore, risk ratings draws through this process shall be incorporated in risk registers.

7.4.5 *Risk Prioritization*

Risk prioritization is the process of determining risk management priorities by comparing the level of risk against predetermined target risk levels and tolerance thresholds. Risk should be viewed not just in terms of financial impact and likelihood, but also subjective criteria such as health and safety impact, corporate social responsibility perspective, vulnerability, and speed of onset.
It is recommended to risk owners that risk prioritization should be determined by applying agreed-upon criteria and then transfer this risk priority to risk register. For general guidance, examples of these criteria include:

Adaptability: The capacity of the department individually & SNGPL as an entity to adapt and respond to risks (e.g., responding to changing requirement of Material & Design in product development process and its impact on business objectives of SNGPL relating to Projects).

Complexity: The scope and nature of a risk to the SNGPL's success. The interdependency of risks will typically increase their complexity (e.g., risks of material obsolescence and timely unavailability to a project's objective in supply management structure.)

Velocity: The speed at which a risk impacts any department individually & SNGPL as an entity. The velocity may move SNGPL away from the acceptable variation in performance. (e.g., the risk of disruptions due to strikes by contractors, suppliers & union groups affecting the objective relating to efficient functioning of SNGPL).

Persistence: How long a risk impacts SNGPL? (e.g. The persistence of adverse media coverage and impact on strategic objectives following the identification of mega corruption at any level.)

Recovery: The capacity of SNGPL to return to tolerance (e.g., continuing to function of spreading pipelines after a severe earthquake or other natural disaster). Recovery excludes the time taken to return to tolerance, which is considered part of persistence, not recovery.

Risk owners are advised to prioritize identified risks by taking into account the severity of the risk compared to risk appetite. Greater priority may be given to those risks likely to approach or exceed risk appetite.

7.5 Risk Treatment

A risk treatment strategy is a plan which seeks to mitigate the risks and safeguard investment and service delivery activities. This is achieved through proactive actions that reduce either:

I. The likelihood of a risk occurring or
II. The impact of a risk.

7.5.1 *Process Flow for Conducting Risk Treatment*

Once Risk Identification & Risk Assessment process is completed, the next step is to perform risk treatment. This shall be performed as follows;

RO are advised to provide guidance about risk treatment options mentioned in Risk Treatment Matrix **(see 7.5.2 below).** This shall help the risk owners to select the best treatment option to mitigate the risk. Once treatment option is determined, record the selected treatment option in the "Treatment Option column" in the Risk Treatment& Schedule Plan template **(Refer to Annexure H).**

7.5.2 *Risk Treatment Matrix*

Depending on the type and nature of the risk, risk owners have following options:

The risk management manual outlines several risk treatment options. These options provide a range of actions that risk owners can take to manage and mitigate identified risks.

The risk treatment options provided in the sources include:

- **Avoid:** This involves deciding not to proceed with the activity that introduces the unacceptable risk. It could mean choosing an alternative, more acceptable activity that still meets business objectives, or opting for a less risky approach or process. An example is ceasing a product line or declining to expand and spread pipelines in a terrorist-declared area. Choosing avoidance suggests that the department owners cannot identify a response that would reduce the risk to an acceptable level of severity.
- **Reduce:** This entails implementing a strategy designed to lessen the severity of a risk to an acceptable level. This option is considered when eliminating the risk entirely is deemed excessive in terms of time or expense. The strategy should align with the target residual risk profile and risk appetite.
- **Share or Transfer:** This means implementing a strategy that shares or transfers the risk to another party or parties. Examples include outsourcing the management of physical assets or purchasing insurance contracts for all vehicles owned by SNGPL. The third party accepting the risk should be aware of and agree to accept this obligation. Sharing or transferring risk lowers residual risk in alignment with risk appetite.

- **Accept:** This entails making an informed decision that the risk rating is at an acceptable level or that the cost of the treatment outweighs the benefit. This option may also be relevant when a residual risk remains after other treatment options have been implemented. No further action is taken to treat the risk or change

the severity of risk; however, ongoing monitoring is recommended. This response is appropriate when the risk to strategy and business objectives is already within risk appetite. Risks that are outside the SNGPL's risk appetite and that department owners seek to accept require approval from the MD & Risk Management Committee.

- **Pursue:** This involves taking an action that accepts increased risk to achieve improved performance. This may involve adopting more aggressive growth strategies, expanding operations, or developing new products and services. When choosing to pursue a risk option, management should understand the nature and extent of any changes compulsory to achieve desired performance while not exceeding the boundaries of acceptable tolerance.

Once actions area addressed risk owners will record the action in the “actions” column in Risk Treatment & Schedule Plan template **(Refer to Annexure H).**

7.5.3 *Response to Risks*

The results of the risk assessment process then serve as the primary input to risk responses whereby Risk Owners shall be required to examine & select response options against identified risk (accept, avoid, pursue, reduce or share). While deciding risk response it is essential for risk owners to carry out cost-benefit analysis, formulate a response strategy, develop a risk response plan and get it approved by Departmental / Regional Head.

For monitoring purpose & subsequent follow-up action, ROs are required to review & assess department's risk response plans in order to ascertain that risk responses are align with risk appetite.

7.6 Overall Monitoring & Review

The Risk Owner shall make arrangements to identify & treat risks and focal person of relevant department monitor progress and consider the effect on the overall risk rating and those changes and updates are reflected in the Risk Register on monthly basis. Risk officers of each department shall review the progress and prepares a report to present his relevant Chief Officer / Chief Engineer.

It is required from every Departmental / Regional Head to regularly review risks identified, assessed, treated and all related information in the risk register to ensure it is comprehensive and up to date. Any actions or events that change the status of a risk shall be timely documented, for example:

- Changes to a risk evaluation as a result of improvements in controls or change in internal and external factors.
- A control breach and near miss should be logged at the time of the event
- A new risk that has been identified.

Monitoring and review should be a part of the risk management process and involve regular reviews. The results should be recorded and reported within the department as well as Risk Management Department. The results should also be an input to the review and continuous improvement of the SNGPL's risk management framework. A sample format for Risk Monitoring and Review is available in **Annexure I.**

The Risk Management Department's monitoring and review processes shall encompass all aspects of the risk management for the purposes of:

- Ensuring that risk management process has been followed by all departments as per guidelines provided.
- Obtaining further information to improve risk assessment.
- Analyzing and learning lessons from risk events, including near-misses, changes, trends, successes and failures.
- Detecting changes in the external and internal factors, including changes to risk criteria and to the risks, which may require revision of risk treatments and priorities.

After providing detailed guidance about how to implement risk responses and management techniques, the **RO** needs to monitor the actual activities to ensure that the identified risk stays within an acceptable threshold.

As part of the monitoring process, the thresholds for the risk criteria should be reviewed at the commencement of each risk assessment cycle to identify the processes that may be subject to increased risks and, as such, would derive the greatest value from the risk assessment.

Risk Trend

The risk trend provides another dimension to the assessment and management of risk by indicating the direction of travel of a risk, which with proximity help prioritize management attention where more than one risk share the same risk scores.

There are trends;

- **Static**- Risk level remains same as identified before
- **Increasing**- Risk level start increasing as identified before
- **Decreasing**- Risk level start decreasing as identified before

7.7 Risk Register

To manage risk effectively across the organization, key stakeholders must have full knowledge of the range of risks that SNGPL faces, including how these risks might change with time, and the associated risk control strategies. The most common way to document this information is by using risk registers. It is suggested that risk registers are maintained at regional and departmental level.

A risk register is simply a list of the identified risks and assessed using its risk management process. It will provide a holistic view of the risks faced by SNGPL and enables key stakeholders to make informed decisions regarding risks and their management.

A risk register also helps meet the information needs of the Risk Committee, members of the boards, executives and other relevant stakeholders.

A risk register typically contains the following information:

- Risk ID (this is a unique identifier)
- Name of the person(s) who did the assessment (Risk Owner)
- Description of the risk
- Risk assessment information, such as:
    - The worst-case impact, likelihood and risk level
    - The current controls and their effectiveness
    - The current impact, likelihood and risk level
    - Whether the risk is acceptable or tolerable
    - Additional treatments if the risk is not acceptable or tolerable
    - The residual risk level once additional treatments have been implemented.
- Risk owner – who is responsible for managing the risk
- Monitoring information – how and when the risk and its controls will be reviewed and reported
- The date the risk register was last updated
- Risk category (e.g. Financial, Service Delivery, Work Health and Safety). A

standard Risk Register format is attached. **(Refer to Annexure K).**

7.8 Reporting

The purpose of risk reporting is to create awareness of key risks, improve accountability for the management of risk, timely completion of risk treatment plans and documenting the activities performed in relation to risk management. BOD & RMC shall require information to be reported that allows them to be aware of the integrity of managing risks across SNGPL. GM - Risk Management shall determine the form of reporting to and from Risk Management Department necessary to best inform the BOD & RMC.

7.8.1 *Department's Risk Reporting*

Risk Management process can only be effective when timely reporting is carried out by risk owners/focal person to their respective risk officers. Risk management process presented and addressed in different sections of manual describes the reporting requirement from every department. For this purpose, RO shall guide the focal person from every department to report on following:

- Focal person shall have the responsibility to prepare minutes of every session/meeting conducted by Risk Management Department and email them to his Departmental / Regional Head also copying respective RO.
- Focal person from every department shall require submitting a status report on progress of risk treatment & action plans on fortnightly basis.
- Although risk owners are accountable for the effective management of identified risk but focal person shall have the responsibility to update risk register in co-ordination with risk owners &Departmental / Regional Heads and also submit with Risk Management Department on monthly basis.
- Focal person shall have the responsibility to submit all relevant forms (Identification/assessment/treatment/monitoring etc.) to Risk Management Department within 5 working days after the sessions are conducted and thereafter in continuity
- Focal person shall update RO about those risks, if any, which are not effectively addressed through risk register and about risks for which existing status has been changed significantly.
- Any other matter / report that is considered relevant for effective risk management

7.8.2 *Reporting to RMC by Risk Management Department*

Reporting to RMC shall present a more granular level and assist RMC on strategy setting and support in planning and achieving strategic objectives on SNGPL while giving due consideration to relevant risks.

Risk Management team shall prepare reports for RMC in accordance with their risk management responsibilities and includes report on:

- Overall view of risk, SNGPL as an entity faces, by gathering information of key risk indicators from every department. This will outline the tolerance of SNGPL as a whole and potential risk to a strategy or business objective.
- Submission of annual risk management plan
- Tracking of risk management plans & initiatives for establishing ERM practices throughout SNGPL.
- Risk Management Department shall report on regular basis about the progress of annual plan in relation to actual vs. planned activities
- Disclosure of unusual incidents & significant breaches happened if any;
- Assessment of cultural trends before & after risk management presentations in various departments

An illustrative template for reporting to RMC is provided in **Annexure L**.

7.8.3 *Reporting Attributes*

Risk Management team shall form reports including quantitative & qualitative information about risk from being fairly simple to more complex gradually depending upon risk management culture developed and activities performed over a period of time.

In risk reporting, historical information could relate but an emphasis of being forward looking & considering new trends shall be more beneficial.

Reports shall reflect knowledgeable information about end to end steps taken to fulfill risk management objectives and shall help senior management to connect historical information to potential early-warning information.

Above all, Risk Management Department shall ensure that risk reporting is accurate, clear and complete.

7.9 Reporting to MD

The effectiveness of ERM is highly dependent on the effectiveness of information & communication about SNGPL's performance, which is considered to be an important component of Enterprise Risk Management. It is essential to communicate risk management information to MD on an adequate frequency. The objective is to enable decision makers to evaluate risk management performance monthly or even real time, as the nature of the risk & circumstances indicates.

7.9.1 *Responsibility*

The Managing Director is reportable to the board of directors and is responsible for overall enterprise risk management culture, capabilities, and practices required to achieve the SNGPL's objectives. In order to accomplish this purpose, he is required to be well-informed about relevant risks while taking a decision.

Risk Management Department shall report the Risk Management activities to the Managing Director through DMD (Services) on a monthly basis.

The quarterly progress report shall be sent to Management Committee through DMD (Services) for its review and onward submission to Risk Management Committee of the Board of Directors. The GM (Risk Management) has the prime responsibility for reporting to MD through DMD (Services). An illustrative template for reporting to MD is provided in **Annexure M**.

7.9.2 *Reporting Requirement*

The monthly and quarterly reports shall include the following information:

- Current update of the Risk Management activities for the reporting period along with any issues faced.
- It shall annex the minutes of all trainings / workshops / and any other workgroup activities conducted during the reporting period.
- It shall annex the updated risk registers, received from all departments, as of reporting date.
- The issues SNGPL as an organization faces towards successful implementation of ERM.
- Any key risk areas that need to be addressed in urgency.
- A section for 'Risk Prevention' for any identified risk sensitive areas where appropriate. MD shall consult with the DMD (Services) and GM (Risk Management) and concur on proactive strategic management of the identified existing or potential risks / risk areas.
- Annual Risk Management Plan after getting it approved by RMC.

- Details of accomplished risk management activities as per Annual Risk Management Plan i.e. actual vs. planned status of activities.

7.9.3 *Reporting Timelines*

- ✓ The monthly progress report shall be submitted to Managing Director through DMD (Services) by 10thof the following month.
- ✓ The quarterly progress report shall be submitted to Managing Committee by 30thof the month following the close of a quarter.
- ✓ The reviewed quarterly progress report by Management Committee shall be submitted to Risk Management Committee of the Board of Directors in their upcoming scheduled meeting.

7.9.4 *Meetings with MD*

Monthly meeting shall be held with MD to provide status of activities related to risk management conducted during a month & the issues addressed thereof. DMD (Services) and GM - Risk Management will brief Managing Director departmental risk registers and other risk management activities in order to communicate thorough understanding of risks raised in every functional unit across SNGPL. Consent of the Managing Director shall be sought on the action plans required for any emergency issues.

7.10 Implication of Risk Management Function

Risk measurements have limited value unless the Risk Management Function has a robust procedure for monitoring, feedback, and action.

Risk management is a dynamic process in which information flows from line managers up to senior managers who monitor progress and, when necessary, develop action plans and send instructions back down to line managers.

The nature of new initiatives approved and the triggers for acceleration or corrective action all depend on a SNGPL's risk appetite. ERM implementation requires a company to create a risk appetite statement that defines how much risk it will take in pursuit of its business strategy. For strategic risks, the risk appetite metrics are typically defined through the potential impact on earnings, enterprise value from adverse business decisions, or lack of response to industry changes.

7.11 Conclusion

Risk management function is intended to improve the Risk awareness culture within SNGPL and co-ordinate with all departments for successful implementation of Risk Management Procedures, but it is each department individual responsibility to Identify & manage their risk. Risk Management Department can help as a catalyst in monitoring risk function.

One key benefit of risk management is early warning of potential problems. If an initiative falls behind expectations, alarms sound. Management then has the opportunity to redirect the effort & lay off risk.

Management of each department should identify all possible risk that may impact the success of SNGPL, ranging from the larger or more significant over business risk down to the less important risk associated with individual projects or smaller business units in a reasonable time period.

Risk identification should be an explicit step in SNGPL's strategic planning cycle. At each level of planning in SNGPL's annual business planning process, there should also be an examination and analysis of risks, current and emerging. This consideration for risk should be conducted at unit level and department level, as well as enterprise level. The risks should be examined and the responses determined.

This would require consideration of those risks that might arise in the longer-term planning horizon. Identification of the emerging risks during strategic planning will be more important than acknowledging the current risks inherent to the business.

The greatest reward of Risk Management should be a shift from reacting to crises to being aware of & managing risk before they could occur. Being in control, having structure and being organized Risk Management allows for a business environment within SNGPL that is empowering and permits taking advantage of opportunities.

8 TRAINING AND DEVELOPMENT IN RISK MANAGEMENT

SNGPL seeks to attract, motivate and retain the best people in the right positions, as needed, to enable the organization to successfully achieve its objectives. For this purpose, Risk Management Department will work with employees to ensure they have the requisite skill sets and continually enhance their capacity to undertake the job of risk management that SNGPL requires them to do.

This section provides guidelines for training & development in risk management function to upgrade their skills for smooth execution of their scope of activities. Risk Management team's preliminary task is to build risk awareness within the SNGPL at all levels. For this, Risk Management Department staff should have hands on knowledge & training to conduct the activities related to Risk Management, to achieve Risk Management objectives & to develop required deliverables/ reports.

8.1 Purpose

To proactively address risks, the risk management team needs to provide risk management training to the operational staff as and when required. Training & Development of Risk Management Department staff is necessary not only to train operational staff about risk management but also for their own proper functioning. The challenge with the risk management officials is to determine the requirements and level of the training, and the population size.

The main objective of training and development of Risk Management Department staff is to help develop key competencies regarding risk management which enable risk officers to perform current or future jobs successfully.

To improve operational efficiency and productivity of Risk Management Department staff and developing their potential to train other departments, for maximization of mutual benefit to individuals & SNGPL.

8.2 Policy

The basic policy in administering and implementing any type of training or development activity regarding risk management is in accordance with the strategic business objectives of SNGPL. The Human Resources Department along with SNGTI will work closely with GM - Risk Management in assessing areas that need training and development support.

Furthermore SNGTI, in consultation with each Departmental / Regional Head and in collaboration with the Risk Management Department staff will, up to the maximum extent possible, determine training needs for the employees of other departments. Specific trainings may be arranged, subject to the availability of resources and approval of the management.

8.3 Types of Training/ Development Activities

Staff training/development activities can be initiated by Risk Management Department employees and shall discuss and submit requirements for specific training areas to GM - Risk Management for arranging training in consultation with SNGTI.

In order to create risk awareness culture among SNGPL employees, GM - Risk Management shall also suggest trainings for employees of other departments.

The Risk Management Department training and development program may include the following;

8.3.1 Proposed Courses / Certifications for Personnel of Risk Management Department

Risk management officials with advance skills in Risk Management, can perform their function & conduct specialized tasks attuned to the needs of SNGPL that is expected to become complex & virtual. Following are few suggested professional courses that may help Risk Management Department personnel in achieving professional excellence, however following list is not exhaustive & other suitable professional courses of same level may also be considered;

The source provides a list of professional courses and certifications that may help Risk Management Department personnel in achieving professional excellence. These certifications can equip risk management officials with advanced skills to perform their functions and conduct specialized tasks aligned with the needs of SNGPL.

Here is a list of the certifications, along with the awarding bodies:

- **Chartered Enterprise Risk Analyst® (CERA)** awarded by SOA
- **Financial Risk Manager (FRM)** awarded by GARP
- **Professional Risk Manager (PRM)** awarded by PRMIA
- **Certificate in Enterprise Risk Management** awarded by IRM
- **Certification in Risk Management Assurance (CRMA)** awarded by IIA
- **Certified Risk Management Professional (CRMP)** awarded by RIMS
- **Certified in Risk and Information Systems Control (CRISC)** awarded by ISACA
- **Risk Management Professional (RMP)** awarded by PMI

Chartered Enterprise Risk Analyst® (CERA) (US)

The CERA qualification provides risk professionals with strong ERM knowledge that drives better business decisions. Professional, ethical and trusted, with impeccable standards and integrity, a professional with the CERA qualification is able to communicate effectively ideas with leadership and is qualified to play varying roles within an organization, from risk manager to Chief Risk Officer (here Senior General Manager) and more.

The **CERA Education Syllabus** covers seven areas of learning objectives:

- ERM concept and framework
- ERM process
- Risk categories and identification
- Risk modeling and aggregation of risks
- Risk measurement and assessment
- Risk management tools and techniques

A CERA offered by the Society of Actuaries (SOA) (US) has demonstrated knowledge in the identification, measurement and management of risk within risk– bearing enterprises.

For further guidelines please follow the link:

https://www.soa.org/Education/Exam-Req/edu-cera-req.aspx

Financial Risk Manager (FRM) (US)

GARP (Global Association of Risk Professionals) sets the global standard in professional certification with the **FRM (Financial Risk Manager)**. Developed by the world's leading risk practitioners, the designation signifies a mastery of the essential skills and knowledge needed to help organizations dealing with Risk Management, succeed in today's rapidly changing financial landscape.

In context of future perspective of Risk professionals working in SNGPL, this certification will help them in investment risk management and other areas of financial sector to broaden their knowledge of different types of financial risks that finance department may faces. Certified FRM have a prospect to achieve positions such as Chief Risk Officer (here Senior General Manager), Senior Risk Analyst, Head of Operational Risk & director of Risk Management.

For further guidelines please follow the link:

http://www.garp.org/#!/frm

Professional Risk Manager (PRM) (US)

The **Professional Risk Managers' International Association** (**PRMIA**) is a professional organization focused on the "promotion of sound risk management standards and practices globally", and "the integration of practice and theory. It provides certification and credentialing for professional risk managers, as well as other educational programs and resources.

The **Professional Risk Manager (PRM)** Designation is a globally recognized, graduate-level risk management credential. The PRM Program is a series of certification exams, designed to measure the knowledge of professional risk managers and ensure they meet a specific performance standard in their profession.

For further guidelines please follow the link:

https://www.prmia.org/Public/PRM/Public/PRM/PRM.aspx?hkey=70930e7c-622e- 4488-b789-8342795ee6f6

Certificate in Enterprise Risk Management (UK)

The **International Certificate in Enterprise Risk Management** offered by Institute **of Risk Management (IRM)** is the ideal qualification for anyone looking for a solid foundation in the theory and practice of effective risk management. Risk Professional in SNGPL will be able to achieve detailed understanding of current drivers of ERM including the following;

- The concepts and definitions of risk and risk management
- Risk management standards
- Enterprise risk management
- Risk assessment, identification, analysis and evaluation
- Risk responses and risk treatment
- An overview of the global business and risk environment
- Risk architecture, strategy and protocols
- Risk culture, appetite and tolerance
- Risk and organizations, including an introduction to corporate governance, project and operational risk management, and supply chain management
- Organizational risk management, emerging risks and future developments

The Certificate is made up of two modules which are designed to be studied together. Learning in module 1 explores elements of the risk management process, while module 2 explains how organizational culture and appetite for risk may affect the implementation of such processes.

For further guidelines please follow the link:

https://www.theirm.org/qualifications/international-certificate-in-enterprise-risk-management.aspx

Certification in Risk Management Assurance (CRMA) (US)

The **Certification in Risk Management Assurance® (CRMA®)** offered by The **Institute of Internal Auditors (IIA)** focuses on the key elements to unlocking **internal audit's** full potential, and validates one's ability to provide advice and assurance on risk management to board committees and executive management.

For further guidelines please follow the link:

https://na.theiia.org/certification/crma-certification/Pages/CRMA-Certification.aspx

Certified Risk Management Professional (CRMP) (US)

The **Certified Risk Management Professional** (**CRMP**) offered by **The Risk Management society (RIMS)** is a credential that demonstrates your achievement of risk management competencies, knowledge and commitment to quality. This certification defines the highest achievement of risk management competencies for the risk management professional. Individuals who earn the CRMP have demonstrated their knowledge and competency in the area of risk management, and are dedicated to upholding high standards of ethical and professional conduct.

For further guidelines please follow the link:

https://www.rims.org/Certification/Pages/Home.aspx

Certified in Risk and Information Systems Control (CRISC) (US)

The **Certified in Risk and Information Systems Control (CRISC) offered by** ISACA **(Information Systems Audit and Control Association)** qualification was specifically created for risk and control professionals to identify and manage risks

through the development, implementation and maintenance of information systems (IS) controls.

This certification will specifically help those Risk Professionals monitoring the IT infrastructure of SNGPL with respect to Risk Management.

For further guidelines please follow the link:

http://www.isaca.org/Certification/CRISC-Certified-in-Risk-and-Information-Systems-Control/Pages/default.aspx?utm_referrer=

Risk Management Professional (RMP) (US)

The RMP certification offered by Project Management Institute acknowledges the Risk Professionals unique expertise on the project team while demonstrating the recognition and value the role provides to the project management profession. This certification holder will help those Risk professionals who will be having responsibility to monitor Project related risks. This will enable them to have more competence in the specialized area of assessing and identifying project risks while mitigating threats and capitalizing on opportunities than a general practitioner and yet, also maintains a basic level of competence in all areas of project management.

For further guidelines please follow the link:

https://www.pmi.org/certifications/types/risk-management-rmp

8.3.2 Orientation for New Hires

It is important that new hires in Risk Management Department understand the full scope of their responsibilities in order to be fully prepared for their new role. For this purpose, an orientation workshop shall be conducted for them to provide an overview of SNGPL business, operational activities and risk management framework.

GM - Risk Management will ensure that all new staff members will receive an introductory orientation session upon joining which should include but not limited to;

- Understanding of Business and Operational activities of SNGPL
- Risk Management Framework for SNGPL
- Role of Risk Management Department (Functions, Structures, Environments etc.)
- Relevant Code of Conduct

- Policies and Procedures of Risk Management Department

8.3.3 Cross Functional Training for Risk Management Department Staff

Risk Management Department is required to keep its staff members up to date with risk management skills and knowledge of various functions. The objective is to ensure that a continuous professional development culture relating to learning and competence is maintained at highest level to create improvements & skills enhancements. This shall ensure professional execution of duties throughout risk management function. Therefore, Risk Management officials have the implied responsibility to keep abreast of developments and knowledge in their area of expertise to ensure their professional competence. In order to have a common knowledge bank, brainstorm of practical issues and have a standardized approach towards management of risks, each RO shall arrange sessions (as a subject expert) in relation to their areas for other employees of Risk Management Department after approval of GM - Risk Management. Following shall be covered in these sessions;

- On Job training- Interactive & participative discussion
- In-house presentation on risks identified and mitigated in the specific areas of subject expert
- Technical issues faced while implementing risk management process in their specific areas
- Development of in-house risk training programme

8.3.4 Training for SNGPL Staff

- The risk management team needs to identify the training requirement of employees in certain departments.
- A training deployment strategy should be formulated in consultation with SNGTI and relevant Head of Department which shall cover the content and the number of hours of training to be provided for each level.
- Departmental / Regional Heads are required to determine the training progress under their supervision regarding risk management within their areas of scope. This performance indicator will help in assessing the capability of the SNGPL as a whole for managing risks.

Providing proper training is the basic building block for successful risk management. The provision of training to business operation, services and other resources provides the key to mitigating risks efficiently and effectively. All efforts should be made to identify the training requirements and select relevant participants.

8.3.5 Training from External Resource

Risk Management Department employees shall have access to external training programs that are organized by external training resources and market experts in order to enhance their risk management skills. External training may be imparted to employees through various training institutions. GM -Risk Management Department in consultation with SNGTI & SGM - HR may recommend an expert competent to deliver required training. Risk Management. Upon approval, all arrangements will be carried out by SNGTI.

RELATED RECORDS

Training record will be maintained by SNGTI. It may include;

- Yearly Training Plan
- Training Attendance Sheet
- Training Evaluation Form
- Training Feedback Form

8.4 Training Need Assessment

A "need" refers to the gap between what is and what could or should be within a particular context, leading to strategies aimed at eliminating the gap between what is and should or could be. In order to develop the relevant and specific training contents, there shall be a detailed discussion between GM – Risk Management and selected participants to understand and clarify the following;

- **Current Roles:** What do the employees presently do in their roles?
- **Knowledge Requirements:** What do the employees need to know and do as a result of this training?
- **Outcome:** How will training help to fill this gap?

The GM – Risk Management along with consultation of relevant CO / CE shall identify and compile training needs of the employees of Risk Management Department at the commencement of each financial year. The following factors will be considered while outlining the training requirements:

- Change in the job responsibilities
- Areas for improvement of employee

- Introduction to new skill
- Professional development

For this purpose, a Training Need Assessment (TNA) of an employee shall be carried out according to his job position and nature of the work by preparing a skill matrix required for relevant position.

Upon identification of the Training Need, the CO / CE will compile the TNA and prepare a tentative annual training plan which shall be approved by GM - Risk Management. However, if any specific training need identified during the year, is not a part of already approved plan then CO / CE shall seek approval of same from GM - Risk Management by providing reasons. An illustrative template for training plan is provided in **Annexure N**.

9 GUIDELINES TO INTRODUCE RISK MANAGEMENT CULTURE

9.1 Risk Culture

Risk culture is the values, beliefs, knowledge and understanding about risk, shared by a group of people with a common intended purpose, in particular the leadership and employees of an organization.

SNGPL's core values are fundamental to ERM and these core values shall be reflected in actions & decisions applied across the entity. Without strong & supportive understanding of, and commitment to, those values communicated from the top level of SNGPL, risk awareness may be undermined and risk inspire decisions may be inconsistent with those values.

It is required to ensure that the Risk Management function has support and understanding at the Senior Management and Board levels. Considering the vast diversity of SNGPL, it will be effective to establish Risk Management positions in the first line in addition to the centralized function in SNGPL.

Risk communication should as far as possible be pro-active and it is important that all departments consider their ownership towards risks related to their departments.

9.2 Importance of Risk Culture

It is inexorable that SNGPL would face and subsequently undertake many risks to achieve its objectives. The risk culture within SNGPL can make it remarkably better or worse at managing these risks. Risk culture significantly affects the potential to take risk based decisions and achieve the objectives.

Inapt risk culture at SNGPL could potentially lead to departments / regions operating in nonconformance of established policies and procedures.

An appropriate risk culture means that not only certain individuals or teams will undertake these activities but that the rest of the organization will also participate in risk management activities. Otherwise, achievement of strategic, tactical and operational goals will be hampered.

9.3 Role of Board in Risk Culture

Corporate governance best practices around the world are increasingly demanding that boards of organizations should understand and address their risk cultures. The board is ultimately responsible to set, convey and uphold a risk culture that reliably impacts, coordinates and lines up with the strategy and objectives of the business and strengthens an embedded risk management framework. Embedding risk management involves an environment that can demonstrate leadership from senior management, involvement of staff at all levels, a culture of learning from experience,

appropriate accountability for actions and timely communication on risk issues. This starts with the risk behaviors, attitudes and culture of the board itself and reaches down through the organization.

9.4 Characteristics of an Effective Risk Culture

A successful risk culture would include:

- A distinct and consistent tone from the top from the board and senior management in respect of risk taking and avoidance (and also consideration of tone at all levels)
- A commitment to ethical principles, reflected in a concern with the ethical profile of individuals and the application of ethics and the consideration of wider stakeholder positions in decision making
- A common acceptance through the organization of the importance of continuous management of risk, including clear accountability for and ownership of specific risks and risk areas
- Transparent and timely risk information flowing up and down the organization with bad news rapidly communicated without fear of blame
- Encouragement of risk event reporting and whistle blowing, actively seeking to learn from mistakes and near misses
- No process or activity too large or too complex or too obscure for the risks to be readily understood
- Appropriate risk-taking behaviors rewarded and encouraged and inappropriate behaviors challenged and sanctioned
- Risk management skills and knowledge valued, encouraged and developed, with a properly resourced risk management function
- Sufficient diversity of perspectives, values and beliefs to ensure that the status quo is consistently and rigorously challenged
- Alignment of culture management with employee engagement and people strategy to ensure that people are supportive socially but also strongly focused on the task in hand.

9.5 Stages for Developing & Maintaining Risk Culture in SNGPL

The following process provides guidelines for developing and maintaining risk culture in SNGPL

Stage I: Building Risk Awareness Culture

At the initial stage Risk Management Department shall guide all departments of SNGPL on creating awareness about risk management through various activities such as:

- Providing communications from leadership using a common risk management vocabulary.
- Clarifying risk management responsibilities and accountabilities.
- Conducting risk management training at various levels based on every department's responsibility towards risk management.
- Establishing forums at various levels for sharing risk related information
- Encouraging people to escalate issues and concerns without fear of retribution.
- Clarifying and communicating roles and responsibilities for the achievement of strategy and business objectives, including responsibilities for the management of risk.
- Aligning policies and procedures with overall risk management strategy and approach.

Stage 2: Changing Organization's Culture

At this progressive stage, managements approach is to address and embrace the cultural change, as now they have initiated functioning in an environment that recognizes and rewards people for paying attention to risk, including knowing how to challenge the *status quo* constructively.

Another hallmark of this stage is the emphasis on the ethical and compliance standards that are important to the organization addressing some ethical standards and code of conducts.

Some important components of changing SNGPL's risk culture are:

- Creating a culture of constructive challenge.
- Emphasis that management addresses risk in pursuit of its performance targets.
- Establish activities to regularly & consistently monitor performance results and changes in the risk profile throughout the SNGPL.
- Embedding risk performance metrics into motivational systems.
- Establishing risk management considerations in talent management processes.
- Position individuals with the desired risk orientation in roles where effective risk management is critical.
- Reinforcing behavioral, ethical and compliance standards.
- Setting strategy explicitly considers risk when evaluating options.

Stage 3: Refining the Organizational Culture

At this level the management of every department, is more experienced and mature at their cultural development, trying to monitor cultural performance versus expectations regarding risk management. And those expectations can be set by various stakeholders, including employees, management, and the board of directors, investors and analysts.

Steps that are typically taken to integrate risk management capabilities & refine culture are;

- Emphasis that Management as a whole will make decisions that are appropriate with their risk appetite & risk profile of SNGPL, and address changes to the profile that occur over time.

- Highlight importance that SNGPL management should have capable individuals, subject matter experts and other technical resources to support decision-making considering risk management at each level.
- Emphasizing that when necessary investments in technology or other infrastructure, is required, management considers the tools required to enable enterprise risk management responsibilities.
- Highlight importance that Vendors, contractors, and other third parties are considered in discussions of risk as a whole
- Integrating risk management lessons learned into communications, education and training.
- Holding people accountable for their actions.
- Refining risk performance metrics to reflect changes in business strategy, risk appetite and tolerance.
- Redeploying individuals to reflect changes to business strategy and priorities.

9.6 Areas to Focus to Build Positive Risk Culture

SNGPL can embrace Risk Management Culture through focusing on these areas:

Proactive Approach

Senior leadership should practice routine communication throughout the organization about why managing risk is important and that being compliant just isn't enough. Develop business continuity plans and emergency or incident response programs that promote ongoing participation.

Maintaining strong leadership

The board & senior management should require placing importance on creating the right risk awareness & tone throughout the entity. Culture and therefore risk awareness cannot be changed form second line team or department functions alone; the organization's leadership must be the real driver of change.

Embedding risk in decision making

Management addresses risk consistently when making key business decision, which includes discussing & reviewing risk scenarios that can help everyone to understand the interrelationship & impacts of risks before finalizing decisions.

Investment in risk management

Invest in training, program development or technology to manage risk.

Create bottom-up communication

Inculcate a communication culture that encourages front-line employees to identify and report potential issues or problems to management. This should allow employees to remain anonymous, if desired, and will require a response by management with the ability for automatic escalation.

Identify, prioritize and monitor risk

Keep employees in the know by maintaining consistent risk management processes across the organization. Also, providing frequent and detailed training for employees will promote improved understanding of various risks that the company is exposed to and will enable employees to appropriately monitor and respond.

Frequently evaluate risk

SNGPL shall routinely evaluate the various risks it is exposed to. This should be part of regular business operations in addition to structured review programs.

Enforcing accountability for all actions

The management documents policies of accountability and adheres to them, demonstrating to personnel that lack of accountability is not tolerated and that practicing accountability is appropriately awarded.

10 ETHICS & STANDARD OF CONDUCT

10.1 Introduction

The purpose of the code of ethics is to state the values to which the Risk Management is committed to, and our ethical principles and standards of acceptable behavior in the Risk Management Department. This code of ethics is applicable to all employees of Risk Management Department.

10.2 Code of Conduct

Risk Management Officials are expected to act in the best interest of SNGPL and the Risk Management Department, and in accordance with the code of ethics & standard of conduct of SNGPL

Risk Management Officials shall exercise honesty, objectivity, integrity, respect, accountability, responsibility and diligence in the performance of their duties and responsibilities.

Risk Management Officials shall perform their duties in accordance with applicable laws, regulations and technical standards, complying with both their specifics and intent.

Risk Management Officials shall not knowingly engage in acts or activities that are discreditable to the profession of risk management or to the SNGPL.

Risk Management Officials must ensure that their actions do not bring the name of SNGPL into disrepute.

Risk Management Officials must avoid conflicts of interest, or the appearance of such, and will disclose any circumstances or interests that might influence judgment and objectivity.

Risk Management Officials shall not accept anything of value from an employee, vendor, customer, supplier, or business associate of SNGPL that could impair or be presumed to impair their professional judgment.

Risk Management Officials must at all times ensure that their outcomes or organizational information is treated in strict confidence.

An advertisement by any official must not contain any statement, promise or recommendation that is fraudulent, untrue or misleading.

Risk Management Team shall present accurately and honestly all facts essential to department’s risk management decisions.

Staff must at all times refrain from discrediting other risk management professionals / disciplines.

Risk Management Staff shall use funds appropriately and in accordance with the constitution and by-laws of SNGPL.

Risk Management Officials are bound by the provisions of this code of conduct and must adhere to the provisions.

10.3 Competence and Professionalism

Risk Management Officials shall strive through personal initiative to maintain professional competence, and keep abreast of emerging issues, world trends, etc. in the field of risk management.

It is strongly suggested that Risk Management Officials continuously and actively participate in formal or informal educational and professional activities related to risk management.

Risk Management Officials shall contribute to the development of the risk management culture through the sharing of skills, ideas, and cooperation to promote and enhance the competence of the risk management in SNGPL

10.4 Integrity

Employees working in the Risk Management Department must possess, in addition to a relevant professional competency, a high level of professional integrity. This professional integrity is decisive to achieve confidence in the Risk Management Department and the department's value. Integrity is perceived through the fairness, care and responsibility put into the tasks performed.

Integrity can be compromised through biased, unethical and illegal acts. Employees in the Risk Management function shall respect and contribute to SNGPL's legitimacy and ethical objectives. Key prerequisites to ensure legitimacy and integrity are a mandate that is grounded at the Board and Executive Management level which defines clearly the Risk Management function's responsibilities and tasks, as well as an organization, access to information and reporting that supports this mandate.

10.5 Sanctions

The standards of conduct set forth in this code of ethics provide basic ethical principles in Risk Management Department of SNGPL.

Risk Management Officials should realize that their individual judgment is required in the application of these principles. However, if at any time any staff member is

believed to be acting unethically or against the best interests of the SNGPL, or against the constitution or by-laws of SNGPL, such conduct will be subject to investigation and could lead to disciplinary action against the staff member, including the possible termination of association with department and expulsion from SNGPL

All staff members of Risk Management Department consent to the provisions of all the policies and procedures relating to the code of conduct.

11 ANNEXURES

The risk management manual includes a list of annexures for illustrative purposes. These annexures are designed to be amended according to the future needs of the Risk Management Department.

The list of annexures includes:

- **A:** Risk Management Department Organogram
- **B:** Annual Risk Management Plan
- **C:** Monthly Plan
- **D:** Monthly Progress Report
- **E:** Activity Based Risk Identification Form
- **F:** Sample Risk Identification Checklist
- **G:** Risk Assessment Form
- **H:** Risk Treatment Schedule & Plan
- **I:** Risk Monitoring & Review Form
- **J:** Feedback Form
- **K:** Risk Register
- **L:** Sample Format for Reporting to RMC
- **M:** Sample Format for Reporting to MD
- **N:** Sample Format for Training Plan

Note: These annexures are for illustrative purpose only and may be amended according to future needs of Risk Management Department.